ĐẠI HỌC QUỐC GIA HÀ NỘI
TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

LƯU VĂN DOANH

HỆ THỐNG PHÁT HIỆN RANSOMWARE DỰA TRÊN PHÂN TÍCH ĐA TẦNG, TÍCH HỢP HỌC TÍCH CỰC & KIỂM CHỨNG ĐỘ TRUNG THỰC XAI

LUẬN VĂN THẠC SĨ KỸ THUẬT PHẦN MỀM

HÀ NỘI - 2026

ĐẠI HỌC QUỐC GIA HÀ NỘI

TRƯỜNG ĐẠI HỌC CÔNG NGHỆ

LƯU VĂN DOANH

HỆ THỐNG PHÁT HIỆN RANSOMWARE DỰA TRÊN PHÂN TÍCH ĐA TẦNG, TÍCH HỢP HỌC TÍCH CỰC & KIỂM CHỨNG ĐỘ TRUNG THỰC XAI

Ngành:	Kỹ thuật phần mềm
Chuyên ngành:	Kỹ thuật phần mềm
Mã số:	8480103.01

LUẬN VĂN THẠC SĨ KỸ THUẬT PHẦN MỀM

NGƯỜI HƯỚNG DẪN KHOA HỌC: PGS.TS. TRƯƠNG NINH THUẬN

HÀ NỘI – 2026

Lời cảm ơn

Trước hết, tôi xin bày tỏ lòng biết ơn sâu sắc tới **PGS.TS. Trương Ninh Thuận**, người đã tận tình định hướng nghiên cứu, cung cấp những góc nhìn khoa học sắc bén và hỗ trợ tôi trong suốt quá trình xây dựng, tối ưu hóa thuật toán và hoàn thiện luận văn này. Những góp ý chuyên môn mang tính hệ thống của Thầy là cơ sở quan trọng giúp tôi hoàn thành các đóng góp cốt lõi của đề tài.

Tôi xin chân thành cảm ơn các thầy cô giáo tại Trường Đại học Công nghệ – Đại học Quốc gia Hà Nội, đặc biệt là các thầy cô trong chuyên ngành Kỹ thuật phần mềm, Khoa học máy tính và An toàn thông tin, đã truyền đạt cho tôi những kiến thức nền tảng vững chắc. Đây là hành trang quý báu giúp tôi tiếp cận và triển khai đề tài nghiên cứu về Trí tuệ nhân tạo có thể giải thích (XAI) và kỹ thuật phân tích mã độc.

Tôi cũng xin gửi lời cảm ơn tới gia đình, bạn bè và các đồng nghiệp đã luôn động viên, chia sẻ và tạo điều kiện thuận lợi nhất để tôi có thể tập trung nghiên cứu, thu thập dữ liệu và hoàn thành luận văn đúng tiến độ.

Mặc dù đã nỗ lực tối đa trong quá trình nghiên cứu, xây dựng hệ thống và kiểm chứng thực nghiệm, song do giới hạn về thời gian cũng như tính phức tạp của sự tiến hóa mã độc, luận văn khó tránh khỏi những thiếu sót. Tôi rất mong nhận được những ý kiến đóng góp quý báu từ Hội đồng bảo vệ và các nhà khoa học để hướng nghiên cứu này được hoàn thiện và có khả năng ứng dụng sâu rộng hơn trong tương lai.

Hà Nội, tháng 06 năm 2026

Học viên

Lưu Văn Doanh

Lời cam đoan

Tôi xin cam đoan luận văn thạc sĩ với đề tài **"Hệ thống phát hiện Ransomware dựa trên Phân tích đa tầng, tích hợp Học tích cực & Kiểm chứng độ trung thực XAI"** là công trình nghiên cứu do tôi thực hiện dưới sự hướng dẫn khoa học của **PGS.TS. Trương Ninh Thuận**.

Các nội dung nghiên cứu lý thuyết, đề xuất kiến trúc hệ thống, thuật toán và toàn bộ kết quả thực nghiệm trong luận văn (bao gồm các chỉ số độ trễ, điểm đánh giá bộ giải thích, và kết quả học tích cực) được trình bày một cách trung thực, dựa trên quá trình tự lập trình, thu thập log hệ thống và phân tích dữ liệu của bản thân. Những tài liệu, công trình nghiên cứu, số liệu và nguồn tham khảo được sử dụng để đối chiếu trong luận văn đều được trích dẫn và ghi rõ nguồn gốc theo đúng quy định học thuật.

Tôi xin cam đoan rằng luận văn này chưa từng được sử dụng để bảo vệ cho bất kỳ học vị nào tại bất kỳ cơ sở đào tạo nào khác. Mọi sự kế thừa, tham khảo từ các công trình nghiên cứu, tài liệu kỹ thuật và nguồn thông tin liên quan đều được thực hiện với tinh thần trung thực và được ghi nhận đầy đủ trong danh mục tài liệu tham khảo.

Tôi xin chịu hoàn toàn trách nhiệm về tính trung thực, chính xác và nguyên bản của luận văn này. Nếu phát hiện có bất kỳ hành vi sao chép, gian lận học thuật hoặc sử dụng kết quả của người khác mà không trích dẫn đúng quy định, tôi xin chịu mọi hình thức xử lý theo quy định của Trường Đại học Công nghệ - Đại học Quốc gia Hà Nội.

Hà Nội, tháng 06 năm 2026

Học viên

Lưu Văn Doanh

Tóm tắt

Mã độc tống tiền tiếp tục là mối đe dọa nghiêm trọng, trong khi hệ thống phát hiện dựa trên Học máy thường phải đánh đổi giữa tốc độ phân tích tĩnh, khả năng quan sát hành vi động, chi phí gán nhãn và khả năng giải thích. Luận văn đề xuất **Hệ thống phát hiện Ransomware dựa trên Phân tích đa tầng, tích hợp Học tích cực và Kiểm chứng độ trung thực XAI** với ba đóng góp: thiết kế dung hợp tĩnh–động bằng PID sau cổng bất định; chiến lược Học tích cực kết hợp độ bất định, Directional Entropy và phương sai SHAP; quy trình đánh giá lời giải thích bằng deletion, Consistency, Contrastive và kiểm tra độ ổn định.

Hai thực nghiệm xác nhận sử dụng 2.000 mẫu EMBER 2018 có định danh tĩnh, gồm 1.500 benign và 500 malware, mỗi mẫu có 2.381 đặc trưng. Dữ liệu và manifest đã được kiểm tra nhãn, SHA-256, chỉ số nguồn và hash vector. Nhãn dương biểu thị malware nói chung, không phải nhãn ransomware đã xác minh. Giao thức Active Learning gồm 5 outer folds, 5 seed mỗi fold, 200 nhãn khởi tạo và 10 vòng truy vấn. So với Random, biến thể $U + H$ tăng ROC-AULC 0,004249 và AP-AULC 0,014985, cùng chiều ở 5/5 fold, đồng thời giảm trung bình 76 nhãn để đạt target. So với Uncertainty, mức tăng tương ứng chỉ là 0,001754 và 0,001401; lợi ích ngân sách không ổn định giữa fold. Kết quả cho thấy XAI-guided sampling cải thiện rõ so với Random nhưng chỉ tạo lợi ích bổ sung nhỏ so với đối chứng mạnh.

Đánh giá Fidelity dùng 5 folds, 5 seed mô hình, hai masking baseline và 20 random controls cho mỗi $k = 10, 25, 50$. Ở $k = 25$, top-SHAP làm AUC giảm 0,135853 dưới mean baseline và 0,125180 dưới median baseline; random masking chỉ làm giảm 0,000530 và 0,000326. Độ ổn định Spearman của global importance là 0,6144 trong cùng fold và 0,5512 khi đổi fold. Kết quả hỗ trợ faithfulness tương đối của thứ hạng TreeSHAP, đồng thời cho thấy giải thích nhạy với phân hoạch dữ liệu. OFS chưa được tổng hợp vì các thành phần chưa có chung thang đo và trọng số được kiểm định.

PID hiện được đóng góp ở mức thiết kế và đặc tả đánh giá; dữ liệu EMBER không có báo cáo hành vi động ghép theo SHA-256 nên chưa hỗ trợ kết luận PID giảm FPR. Phạm vi kết luận định lượng của luận văn là phân loại malware tĩnh, hiệu quả ngân sách Active Learning và Fidelity của TreeSHAP trong không gian đặc trưng EMBER.

Từ khóa: *Ransomware*, *Explainable AI (XAI)*, *Học tích cực*, *EMBER*, *LightGBM*, *TreeSHAP*, *Fidelity*.

Abstract

Ransomware remains a serious threat, while Machine Learning detectors must balance the speed of static analysis, behavioral visibility, labeling cost, and interpretability. This thesis proposes a **Multi-Stage Ransomware Detection System integrating Active Learning and XAI Fidelity Verification**. Its three contributions are a design for PID-based static–dynamic fusion after uncertainty gating; an acquisition strategy combining predictive uncertainty, Directional Entropy, and SHAP variance; and an explanation-evaluation protocol based on deletion, Consistency, Contrastive separation, and stability.

Two confirmatory experiments use 2,000 statically identified EMBER 2018 samples with 2,381 features: 1,500 benign and 500 malware samples. Labels, SHA-256 identities, source indices, and feature-vector hashes were verified against a row manifest. The positive label denotes generic malware rather than verified ransomware. The Active Learning protocol uses five outer folds, five seeds per fold, 200 initial labels, and ten acquisition rounds. Compared with Random, $U + H$ improves ROC-AULC by 0.004249 and AP-AULC by 0.014985 in all five folds, while requiring 76 fewer labels on average to reach the validation-defined target. Compared with Uncertainty, the improvements are only 0.001754 and 0.001401, with unstable label-budget gains across folds. Thus, XAI-guided acquisition clearly improves over Random but provides only a small incremental benefit over the stronger baseline.

The Fidelity evaluation uses five folds, five model seeds, two masking baselines, and 20 random controls for each $k = 10, 25, 50$. At $k = 25$, top-SHAP deletion reduces AUC by 0.135853 under the mean baseline and 0.125180 under the median baseline, whereas random masking reduces AUC by only 0.000530 and 0.000326. Global-importance rank stability has a mean Spearman correlation of 0.6144 within folds and 0.5512 across folds. The results support the relative faithfulness of the TreeSHAP ranking while showing sensitivity to data partitioning. OFS is not aggregated because its components lack a validated common-scale normalization and weighting rule.

The PID contribution remains a design and evaluation specification. EMBER provides no dynamic behavior reports paired by SHA-256, so the present evidence does not establish that PID reduces false positives. The quantitative conclusions are limited to static malware classification, Active Learning label efficiency, and TreeSHAP Fidelity in EMBER feature space.

Keywords: *Ransomware, Explainable AI (XAI), Active Learning, EMBER, LightGBM, TreeSHAP, Fidelity*.

Mục lục

Lời cảm ơn **1**

Lời cam đoan **2**

Tóm tắt **3**

Abstract **4**

Mục lục **5**

Danh mục các từ viết tắt **8**

Danh sách bảng **9**

Danh sách hình vẽ **10**

Chương 1 GIỚI THIỆU **11**

1.1 Đặt vấn đề 11

1.2 Đóng góp của luận văn 12

1.3 Cấu trúc của luận văn 13

Chương 2 CƠ SỞ LÝ THUYẾT VÀ TỔNG QUAN TÀI LIỆU **15**

2.1 Đặc trưng tệp thực thi Windows PE và mã độc Ransomware 15

2.1.1 Cấu trúc tệp thực thi Portable Executable (PE) 15

2.1.2 Biểu diễn đặc trưng PE cho mô hình học máy 17

2.1.3 Hành vi và chiến thuật lẩn tránh của Ransomware 18

2.1.4 Mô hình đe dọa và phạm vi phân tích tệp PE 19

2.2 Học máy và Trí tuệ nhân tạo có thể giải thích (XAI) trong An toàn thông tin 21

2.2.1 Mô hình học máy LightGBM trong phân loại mã độc 21

2.2.2 Trí tuệ nhân tạo có thể giải thích (Explainable AI - XAI) và Tree-SHAP 22

2.2.3 Giới hạn của XAI trong phân tích mã độc 24

2.3 Học tích cực (Active Learning) trong môi trường dữ liệu bất cân xứng . . 25

2.3.1 Tổng quan về phương pháp Học tích cực 25
2.3.2 Các chiến lược trích mẫu truyền thống và hạn chế 26
2.3.3 Mất cân bằng lớp, concept drift và thiên lệch truy vấn 26
2.4 Các nghiên cứu liên quan và Khe hổng nghiên cứu (Research Gap) 27
2.4.1 Tổng hợp các công trình nghiên cứu nổi bật 27
2.4.2 Khe hổng nghiên cứu (Research Gap) 29
2.4.3 Định vị nghiên cứu và tiêu chí thiết kế 30

Chương 3 KIẾN TRÚC HỆ THỐNG PHÁT HIỆN RANSOMWARE ĐA TẦNG TÍCH HỢP XAI 32
3.1 Tổng quan kiến trúc hệ thống đề xuất 32
3.1.1 Các phân hệ chức năng 33
3.1.2 Luồng dữ liệu và trạng thái hệ thống 33
3.2 Khung giải thích đa tầng (Multi-Stage XAI Framework) 34
3.2.1 Phân tích tĩnh và tín hiệu giám sát động 34
3.2.2 Cơ chế trọng số thích nghi dựa trên PID 36
3.2.3 Tính chất toán học và phạm vi diễn giải 37
3.2.4 Độ phức tạp và các điều kiện kiểm chứng 38
3.3 Học tích cực hướng dẫn bởi XAI (XAI-Guided Active Learning) 39
3.3.1 Định lượng xung đột đặc trưng (Directional Entropy) 39
3.3.2 Đánh giá độ phân tán giải thích (SHAP Variance) 40
3.3.3 Chiến lược chọn mẫu và tối ưu chi phí 40
3.3.4 Kiểm soát thiên lệch truy vấn và chi phí tính toán 42
3.4 Khung đánh giá XAI định lượng và điều kiện áp dụng cho đặc trưng PE . 43
3.4.1 Phép che đặc trưng và độ trung thực (Faithfulness – FF) 43
3.4.2 Độ nhất quán (Consistency – EC) 44
3.4.3 Độ tương phản (Contrastive – CF) và giới hạn của OFS 45
3.4.4 Sự phù hợp với PE và phạm vi kiểm chứng 45

Chương 4 TRIỂN KHAI THỰC NGHIỆM VÀ ĐÁNH GIÁ KẾT QUẢ 47
4.1 Dữ liệu, môi trường và giao thức đánh giá 47
4.1.1 Phạm vi và nguồn dữ liệu đã xác minh 47
4.1.2 Phân hoạch và kiểm soát rò rỉ 48
4.1.3 Môi trường và cấu hình mô hình 49
4.1.4 Chỉ số và phạm vi đo chi phí 49
4.2 Phân tích và phạm vi đánh giá cơ chế dung hợp đa tầng 49
4.2.1 Bằng chứng hiện có 49
4.2.2 Kết quả phân tích cơ chế 50
4.2.3 Đối chứng cần thiết để xác nhận đóng góp PID 50
4.2.4 Phân tách đóng góp khi tích hợp Học tích cực 51

4.3 Đánh giá mô hình Học tích cực hướng dẫn bởi XAI 51
4.3.1 Biến thể và giao thức đối chứng 51
4.3.2 Hiệu quả đường học và ngân sách nhãn 52
4.3.3 Hiệu quả trong vùng FPR thấp 52
4.3.4 Overhead và ý nghĩa thực tiễn 54
4.4 Đánh giá Fidelity và độ ổn định của TreeSHAP 54
4.4.1 Sự phù hợp của phép đo với dữ liệu mã độc 54
4.4.2 Faithfulness bằng deletion có đối chứng 54
4.4.3 Consistency và Contrastive 56
4.4.4 Lý do chưa tổng hợp OFS 56
4.5 Minh họa giải thích trên một mẫu kiểm thử 57
4.6 Cấu hình đã chạy và dấu vết tái lập 58
4.6.1 Cấu hình cố định 58
4.6.2 Đầu ra và kiểm chứng 59
4.7 Diễn giải kết quả và các mối đe dọa tới tính hợp lệ 60
4.7.1 Tính hợp lệ nội tại 60
4.7.2 Tính hợp lệ ngoại tại 60
4.7.3 Tính hợp lệ của các metric 60
4.7.4 Ý nghĩa đối với ba đóng góp 61

Chương 5 KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN 62
5.1 Kết quả đạt được của luận văn 62
5.2 Hạn chế của luận văn 62
5.3 Hướng phát triển tương lai 63

Tài liệu tham khảo 64

Phụ lục 67
A.1 Thông tin tái lập các thí nghiệm 67
A.2 Schema tham chiếu của đặc trưng PE 2.381 chiều 67
A.3 Quy ước metric và ngân sách AL 68
A.4 Quy ước Fidelity 69
A.5 Điều kiện đánh giá PID 69

Danh mục các từ viết tắt

Viết tắt	Tên đầy đủ (Tiếng Anh)	Giải thích (Tiếng Việt)
AL	Active Learning	Học tích cực
API	Application Programming Interface	Giao diện lập trình ứng dụng
AUC	Area Under the ROC Curve	Diện tích dưới đường cong ROC
CF	Contrastive Fidelity	Độ tương phản (của bộ giải thích)
EC	Explanation Consistency	Độ nhất quán của giải thích
FF	Faithfulness	Độ trung thực (của bộ giải thích)
FPR	False Positive Rate	Tỷ lệ dương tính giả (Báo động nhầm)
I/O	Input/Output	Hoạt động đọc/ghi tệp tin
ML	Machine Learning	Học máy
OFS	Overall Fidelity Score	Điểm trung thực tổng hợp
PE	Portable Executable	Định dạng tệp thực thi trên hệ điều hành Windows
PID	Proportional-Integral-Derivative	Bộ điều khiển tỷ lệ - tích phân - vi phân
RaaS	Ransomware-as-a-Service	Mã độc tống tiền dạng dịch vụ
SHAP	SHapley Additive exPlanations	Phương pháp giải thích mô hình cộng tính Shapley
TPR	True Positive Rate	Tỷ lệ dương tính thật (Tỷ lệ phát hiện)
XAI	Explainable Artificial Intelligence	Trí tuệ nhân tạo có thể giải thích

Danh sách bảng

2.1 Cấu trúc cơ bản của tệp thực thi Windows PE 16
2.2 Phân tích đặc trưng hành vi và kỹ thuật lẩn tránh của các họ Ransomware tiêu biểu 19
2.3 Mô hình đe dọa và phạm vi quan sát của hệ thống 20
2.4 Đánh giá và so sánh các phương pháp Giải thích mô hình (XAI) 22
2.5 So sánh các nghiên cứu liên quan với hệ thống đề xuất của luận văn . . . 29
2.6 Tiêu chí thiết kế hệ thống rút ra từ tổng quan nghiên cứu 31

3.1 Trạng thái logic và dữ liệu trao đổi giữa các phân hệ 34
3.2 Các nhóm đặc trưng của lược đồ EMBER phiên bản 2 35
3.3 Nguồn tín hiệu hành vi trong thiết kế nhánh động 35
3.4 Điều kiện diễn giải và kiểm chứng PID-Fusion 38
3.5 Quy ước lựa chọn mẫu trong thí nghiệm AL 42
3.6 Phạm vi phép che đã thực hiện và điều kiện cần bổ sung cho PE 46

4.1 Phân hoạch trong mỗi outer fold 48
4.2 Vai trò dữ liệu và điều kiện kiểm soát 48
4.3 Các đối chứng xác định đóng góp của nhánh động và công thức dung hợp 50
4.4 Kết quả Active Learning tổng hợp qua 5 outer folds 52
4.5 AULC của các chỉ số vùng FPR thấp 53
4.6 Giảm AUC khi che top-SHAP và che ngẫu nhiên; trung bình qua 25 mô hình 55
4.7 Độ ổn định TreeSHAP giữa các mô hình 56
4.8 Cấu hình hai thực nghiệm xác nhận 58
4.9 Artifacts dùng để truy vết kết quả 59

A.1 Thông tin được lưu để tái lập 67
A.2 Khoảng chỉ số của các nhóm đặc trưng EMBER v2 68
A.3 Quy tắc tính các đại lượng đánh giá giải thích 69

Danh sách hình vẽ

2.1 Cấu trúc cơ bản của tệp thực thi Windows PE 16
2.2 Vòng đời tấn công (Kill Chain) điển hình của mã độc tống tiền 18
2.3 So sánh chiến lược phát triển cây Leaf-wise của LightGBM và Level-wise truyền thống 21
2.4 Quy trình cốt lõi của hệ thống Học tích cực dựa trên tập mẫu (Pool-based Active Learning) 25

3.1 Sơ đồ kiến trúc tổng thể của Hệ thống phát hiện Ransomware đa tầng tích hợp XAI 32
3.2 Luồng xử lý đề xuất với cổng bất định đặt trước nhánh động 36
3.3 Khối cập nhật trọng số có trạng thái của triển khai PID-Fusion tham chiếu 37
3.4 Minh họa khái niệm Xung đột đặc trưng (Directional Entropy) thông qua hai luồng lực đẩy SHAP 39
3.5 Lưu đồ vòng lặp thuật toán Học tích cực hướng dẫn bởi bộ giải thích XAI 41
3.6 Khung đánh giá giải thích và điều kiện sử dụng điểm tổng hợp 43

4.1 Đường học ROC-AUC, AP và các chỉ số vùng FPR thấp từ 200 đến 1.200 nhãn. Dải biến thiên được tính sau khi gộp seed trong từng outer fold. . . 53
4.2 So sánh AULC, ngân sách đạt target và overhead của năm chiến lược. Điểm cuối 1.200 nhãn giống nhau do mọi phương pháp đã dùng toàn bộ pool. 53
4.3 Deletion effect của top-SHAP so với random control dưới mean và median baseline. 55
4.4 Độ ổn định thứ hạng và tập đặc trưng SHAP khi đổi seed hoặc đổi outer fold. 57
4.5 Đóng góp TreeSHAP của mẫu đầu tiên trong test fold 0. Mười chiều có trị tuyệt đối lớn nhất được hiển thị riêng; các chiều còn lại được gộp. . . 58

Chương 1
GIỚI THIỆU

1.1 Đặt vấn đề

Sự phát triển nhanh của công nghệ thông tin làm gia tăng mạnh mẽ nhu cầu lưu trữ, trao đổi và xử lý dữ liệu số. Song song với lợi ích của quá trình số hóa, các cuộc tấn công bằng mã độc tống tiền (Ransomware) trở thành một trong những nguy cơ nghiêm trọng đối với cá nhân, doanh nghiệp và các hệ thống hạ tầng trọng yếu. Khác với nhiều loại mã độc truyền thống, ransomware thường kết hợp nhiều kỹ thuật như mã hóa dữ liệu, xóa bản sao phục hồi, làm rối mã, tiêm tiến trình, trì hoãn thực thi và che giấu hành vi nhằm làm gián đoạn hoạt động của hệ thống, sau đó yêu cầu nạn nhân trả tiền chuộc để khôi phục dữ liệu hoặc ngăn chặn việc công bố dữ liệu bị đánh cắp.

Các phương pháp phát hiện mã độc dựa trên Học máy (Machine Learning) và Học sâu (Deep Learning) đã được nghiên cứu rộng rãi nhờ khả năng khai thác các đặc trưng thống kê, đặc trưng cấu trúc tệp thực thi Windows PE và hành vi thực thi. Các bộ dữ liệu và hệ thống tham chiếu như EMBER và SOREL-20M cho thấy tiềm năng của phương pháp học máy trong phát hiện mã độc ở quy mô lớn [2, 11]. Tuy nhiên, nhiều mô hình đạt hiệu năng dự đoán cao vẫn vận hành như một “hộp đen” (black-box). Trong bối cảnh an toàn thông tin, một cảnh báo chỉ có xác suất dự đoán nhưng thiếu lý do đi kèm sẽ gây khó khăn cho chuyên gia phân tích khi cần xác minh, ưu tiên xử lý hoặc phản biện kết quả của hệ thống. Các khảo sát về XAI cũng chỉ ra rằng tính giải thích và tính trung thực của lời giải thích là hai vấn đề khác nhau; một biểu diễn trực quan dễ hiểu chưa chắc đã phản ánh đúng hành vi nội tại của mô hình [10, 27].

Bên cạnh yêu cầu về khả năng giải thích, ransomware liên tục xuất hiện các biến thể mới và thay đổi kỹ thuật lẩn tránh. Mô hình được huấn luyện trên một tập dữ liệu cố định có thể suy giảm hiệu quả khi phân phối dữ liệu thay đổi. Việc gán nhãn toàn bộ mẫu mới để tái huấn luyện lại tốn kém, đặc biệt khi quá trình phân tích mã độc đòi hỏi chuyên gia có kinh nghiệm. Học tích cực (Active Learning) cung cấp một hướng tiếp cận phù hợp bằng cách chỉ lựa chọn một phần mẫu chưa gán nhãn có giá trị thông tin cao để yêu cầu chuyên gia xác nhận [6, 22]. Tuy nhiên, nếu chiến lược chọn mẫu chỉ dựa vào xác suất đầu ra, hệ thống có thể bỏ qua các trường hợp mà mô hình tỏ ra tương đối tự tin nhưng các đặc trưng nội tại lại xung đột mạnh.

Mặc dù Trí tuệ nhân tạo có thể giải thích (Explainable AI - XAI) đã được ứng dụng trong nhiều nghiên cứu phát hiện mã độc, việc sử dụng XAI thường mới dừng ở mức trực quan hóa hậu kiểm. Vẫn còn thiếu các cơ chế đưa thông tin giải thích vào vòng lặp

vận hành, đặc biệt là lựa chọn mẫu cho Học tích cực và đánh giá định lượng mức độ phù hợp giữa lời giải thích với hành vi của mô hình. Từ khoảng trống này, luận văn đặt ra câu hỏi nghiên cứu thứ nhất: làm thế nào để kết hợp kết quả phân tích tĩnh và giám sát hành vi động trong một hệ thống phát hiện ransomware, đồng thời vẫn cung cấp được thông tin giải thích cho người vận hành? Câu hỏi này hướng tới việc dung hòa giữa ưu thế tốc độ của phân tích tĩnh và giá trị quan sát hành vi của phân tích động.

Câu hỏi nghiên cứu thứ hai xem xét khả năng sử dụng thông tin giải thích của mô hình để hỗ trợ lựa chọn mẫu cho Học tích cực. Cụ thể, luận văn nghiên cứu liệu các tín hiệu như xung đột hướng của giá trị SHAP và độ phân tán của lời giải thích có thể bổ sung cho độ bất định xác suất, qua đó ưu tiên các mẫu có giá trị thông tin cao và giảm chi phí gán nhãn hay không.

Câu hỏi nghiên cứu thứ ba tập trung vào vấn đề kiểm chứng XAI. Thay vì giả định lời giải thích do TreeSHAP sinh ra luôn đáng tin cậy, luận văn xem xét khả năng xây dựng một bộ chỉ số định lượng để đánh giá tương đối độ trung thực, độ nhất quán và khả năng phân tách của lời giải thích trên dữ liệu tệp thực thi Windows PE. Mục tiêu của câu hỏi này không phải chứng minh quan hệ nhân quả tuyệt đối giữa đặc trưng và hành vi mã độc, mà là tạo ra một quy trình kiểm tra có thể lặp lại và so sánh được giữa các cấu hình giải thích.

Xuất phát từ các vấn đề trên, đề tài **Hệ thống phát hiện Ransomware dựa trên Phân tích đa tầng, tích hợp Học tích cực & Kiểm chứng độ trung thực XAI** hướng tới một kiến trúc kết hợp dự đoán, giải thích và cập nhật mô hình. Phần đánh giá định lượng sử dụng 2.000 mẫu từ EMBER 2018 với 2.381 đặc trưng; danh tính mẫu, nhãn, chỉ số nguồn và hash vector đã được đối chiếu bằng manifest. Nhãn dương của EMBER biểu thị malware nói chung, không xác nhận riêng ransomware. Vì vậy, kết quả định lượng được diễn giải ở phạm vi phân loại malware tĩnh và không được mở rộng thành phát hiện ransomware chưa từng thấy, zero-day hoặc khả năng tổng quát hóa theo thời gian. Thiết kế giám sát động được trình bày riêng với các thực nghiệm tĩnh đã có thể truy nguyên.

1.2 Đóng góp của luận văn

Đóng góp thứ nhất của luận văn là thiết kế khung phân tích đa tầng tích hợp XAI, kết hợp LightGBM–TreeSHAP với giám sát động bằng Watchdog Honeypot. Tín hiệu tĩnh được sử dụng tại cổng bất định để quyết định khi nào cần bổ sung phân tích động. Sau khi hai xác suất sẵn sàng, cơ chế PID cập nhật trọng số dung hợp. Cách tổ chức này tách biệt quyết định kích hoạt động và quyết định kết hợp tín hiệu. Hiện chưa có bộ dự đoán tĩnh–động thực ghép cặp đủ để xác nhận PID cải thiện AUC, FPR hoặc chi phí đầu cuối so với dung hợp trọng số cố định; các hiệu quả này là mục tiêu của phép đo tiếp theo.

Đóng góp thứ hai là chiến lược Học tích cực hướng dẫn bởi XAI. Điểm truy vấn

kết hợp độ bất định dự đoán, Directional Entropy và phương sai SHAP sau chuẩn hóa. Directional Entropy mô tả mức cân bằng giữa tổng độ lớn đóng góp SHAP trái dấu; phương sai SHAP mô tả độ phân tán của các đóng góp có dấu. Thực nghiệm trên 5 outer folds và 5 seed mỗi fold đối chiếu Random, Uncertainty, hai cấu hình loại bỏ tín hiệu và cấu hình đầy đủ. Đóng góp được đánh giá bằng AULC, ngân sách đạt target, vùng FPR thấp và overhead, thay vì chỉ so AUC tại một điểm ngân sách.

Đóng góp thứ ba là quy trình đánh giá định lượng lời giải thích trên vector đặc trưng PE. Faithfulness kiểm tra thay đổi dự đoán khi che các chiều được SHAP xếp hạng quan trọng; Consistency đo tương quan giữa cấu trúc tương đồng ở không gian đặc trưng và không gian SHAP; Contrastive đo độ tách hai nhóm nhãn trong không gian SHAP. Thực nghiệm masking sử dụng trung bình từ tập huấn luyện và đối chứng ngẫu nhiên cùng số chiều được chọn. Phép thử hiện thực hiện trên vector, chưa bảo đảm tạo tệp PE hợp lệ. OFS được thảo luận như một quy ước tổng hợp cần thống nhất, không được dùng làm kết quả định lượng hoặc tiêu chuẩn về tính đúng đắn của lời giải thích trong thực nghiệm hiện tại.

Ngoài ba đóng góp chính, luận văn mô tả luồng triển khai từ trích xuất đặc trưng, dự đoán, giải thích và giám sát động đến dung hợp, lựa chọn mẫu, ghi log và dashboard. Hai thực nghiệm xác nhận lưu cấu hình, phân hoạch, mô hình, dự đoán, kết quả replay và SHA-256 của artifacts để kiểm tra lại. Việc lưu các thành phần này hỗ trợ tái lập phép đo trong phạm vi dữ liệu hiện có, nhưng không thay thế đánh giá toàn bộ hệ thống trong môi trường vận hành.

1.3 Cấu trúc của luận văn

Luận văn được tổ chức thành năm chương. Chương 1 trình bày bối cảnh nghiên cứu, các vấn đề đặt ra, ba đóng góp chính và cấu trúc của luận văn. Chương này xác định phạm vi nghiên cứu và làm rõ cách sử dụng các thuật ngữ như biến thể mới, XAI fidelity và phân tích đa tầng.

Chương 2 trình bày cơ sở lý thuyết và tổng quan tài liệu. Nội dung tập trung vào cấu trúc tệp thực thi Windows PE, đặc trưng tĩnh và hành vi ransomware, mô hình LightGBM, phương pháp TreeSHAP, Học tích cực và các nghiên cứu liên quan. Trên cơ sở đó, chương xác định khe hổng nghiên cứu mà kiến trúc đề xuất cần giải quyết.

Chương 3 trình bày kiến trúc hệ thống phát hiện ransomware đa tầng tích hợp XAI. Chương mô tả luồng dữ liệu từ phân tích tĩnh đến giám sát động, cơ chế cổng bất định, dung hợp thích nghi dựa trên PID, chiến lược Học tích cực hướng dẫn bởi XAI và khung đánh giá Fidelity. Các công thức kế thừa từ nghiên cứu trước được trích dẫn tại vị trí sử dụng; các công thức do luận văn đề xuất được chỉ rõ là định nghĩa hoặc quy ước thực nghiệm của nghiên cứu.

Chương 4 trình bày môi trường thực nghiệm, 2.000 mẫu EMBER có định danh

tĩnh, quy trình 5 outer folds và hai đánh giá xác nhận về Học tích cực và Fidelity. Nội dung phân biệt kết quả đo có thể truy nguyên với thiết kế dung hợp chưa có đủ dữ liệu động để kiểm chứng và các minh họa dashboard. Chương này cũng trình bày đối chứng, phạm vi đo chi phí và các mối đe dọa tới tính hợp lệ của kết luận.

Chương 5 tổng hợp các kết quả đạt được, phân tích hạn chế của nghiên cứu và đề xuất hướng phát triển tương lai. Phần cuối luận văn là danh mục công trình khoa học liên quan, tài liệu tham khảo và phụ lục phục vụ tái lập thực nghiệm.

Chương 2
CƠ SỞ LÝ THUYẾT VÀ TỔNG QUAN TÀI LIỆU

Chương này trình bày các cơ sở lý thuyết nền tảng làm tiền đề cho việc xây dựng kiến trúc hệ thống phát hiện ransomware được đề xuất. Nội dung bắt đầu bằng việc phân tích đặc trưng của tệp thực thi Windows PE và hành vi của mã độc tống tiền. Tiếp đó, chương đi sâu vào các công nghệ cốt lõi bao gồm Học máy, đặc biệt là LightGBM, Trí tuệ nhân tạo có thể giải thích với phương pháp TreeSHAP và Học tích cực. Phần cuối tổng hợp các nghiên cứu liên quan để làm rõ khe hổng nghiên cứu, đồng thời xác định phạm vi và mô hình đe dọa mà luận văn hướng tới.

2.1 Đặc trưng tệp thực thi Windows PE và mã độc Ransomware

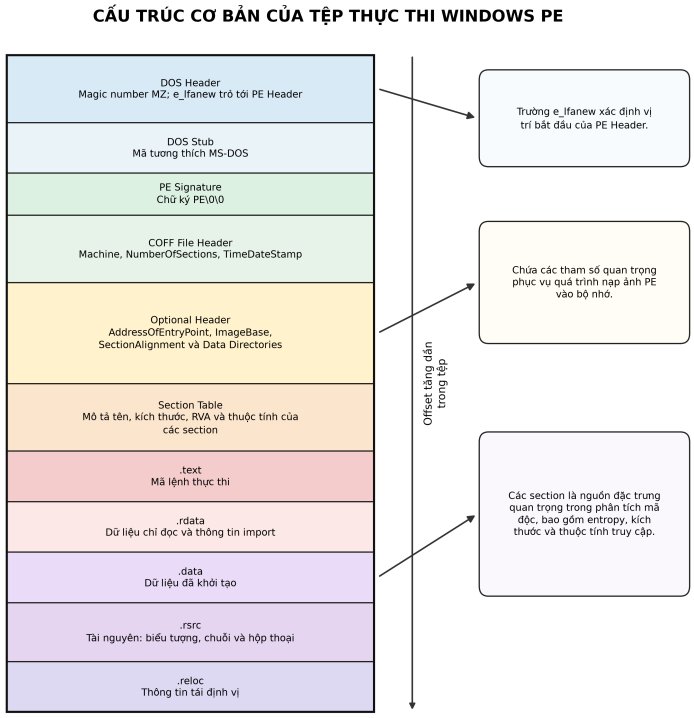
2.1.1 Cấu trúc tệp thực thi Portable Executable (PE)

Portable Executable (PE) là định dạng tệp thực thi tiêu chuẩn trên các hệ điều hành Windows (bao gồm các tệp `.exe`, `.dll`, `.sys`); cấu trúc trường và bảng dữ liệu của định dạng này được Microsoft đặc tả trong tài liệu PE/COFF [16]. Cấu trúc của một tệp PE chứa các thông tin cực kỳ quan trọng để hệ điều hành có thể tải và thực thi mã. Một tệp PE tiêu chuẩn bao gồm các thành phần chính được tóm tắt trong Bảng 2.1.

Bảng 2.1: Cấu trúc cơ bản của tệp thực thi Windows PE

Thành phần	**Chức năng và Ý nghĩa trong phân tích mã độc**
DOS Header	Chứa *Magic number* `MZ` (0x5A4D). Cho phép tệp chạy ở chế độ MS-DOS (thường in ra chuỗi ”This program cannot be run in DOS mode”).
PE/NT Headers	Chứa chữ ký `PE\0\0`, kiến trúc máy (x86/x64), *TimeDateStamp* (thời gian biên dịch), và *AddressOfEntryPoint* (điểm bắt đầu thực thi).
Optional Header	Chứa thông tin về kích thước mã (*SizeOfCode*), *ImageBase*, và bảng thư mục dữ liệu (*Data Directories*) trỏ đến Import/Export tables.
Section Table	Bảng định nghĩa các phần (sections) của tệp như `.text` (mã lệnh), `.data` (dữ liệu), `.rsrc` (tài nguyên). Kích thước bất thường của các section là dấu hiệu mã độc lẩn tránh.

Hình 2.1 mô tả trực quan sơ đồ khối cấu trúc bộ nhớ của định dạng tệp PE khi được nạp vào hệ điều hành.



Hình 2.1: Cấu trúc cơ bản của tệp thực thi Windows PE

Hình 2.1 được biên tập lại từ sơ đồ cấu trúc PE công bố trên Wikimedia Commons và đối chiếu với đặc tả PE/COFF của Microsoft [16, 26].

Đặc biệt, việc tính toán độ hỗn loạn (Entropy) của các phần (sections) là một chỉ báo hữu ích để phát hiện khả năng tệp bị nén (packed) hoặc làm rối (obfuscated). Tuy nhiên, entropy cao không tự nó chứng minh một tệp là ransomware, vì nhiều phần mềm hợp pháp cũng có thể sử dụng cơ chế nén hoặc bảo vệ bản quyền. Theo định nghĩa entropy thông tin của Shannon [23], độ hỗn loạn $H(X)$ của một section được tính bằng công thức:

$$H(X) = -\sum_{i=1}^{n} p(x_i) \log_2 p(x_i) \tag{2.1}$$

Trong đó, X là tập hợp các byte trong section, $n = 256$ (số lượng các giá trị byte có thể có từ 0x00 đến 0xFF), và $p(x_i)$ là xác suất xuất hiện của byte x_i. Giá trị $H(X)$ dao động từ 0 đến 8. Với ransomware bị nén hoặc làm rối, entropy thường tiến gần đến 8; chỉ báo này cần được kết hợp với import API, cấu trúc section và hành vi động để giảm báo động nhầm.

2.1.2 Biểu diễn đặc trưng PE cho mô hình học máy

Phân tích tĩnh chuyển các thuộc tính tệp thành vector số có số chiều cố định. EMBER cung cấp một biểu diễn tham chiếu gồm histogram byte, entropy theo cửa sổ, chuỗi và thông tin cấu trúc PE [2]. Bộ trích xuất EMBER phiên bản 2 trong kho mã có 2.381 chiều thuộc chín nhóm, được liệt kê ở Phụ lục A.2. CSV của thực nghiệm có cùng số chiều; việc xác minh nguồn tạo từng vector được thảo luận riêng trong phần dữ liệu.

Histogram byte là một ví dụ về cách chuẩn hóa tín hiệu từ tệp. Nếu c_b là số lần byte b xuất hiện và n là số byte, tần suất $h_b = c_b/n$ tạo vector 256 chiều với tổng bằng 1 khi $n > 0$. Thông tin entropy kết hợp phân bố byte với tính cục bộ theo cửa sổ để mô tả các vùng dữ liệu có độ hỗn loạn khác nhau. Đây là biểu diễn thống kê, không phải dấu hiệu đủ để phân loại một tệp là ransomware.

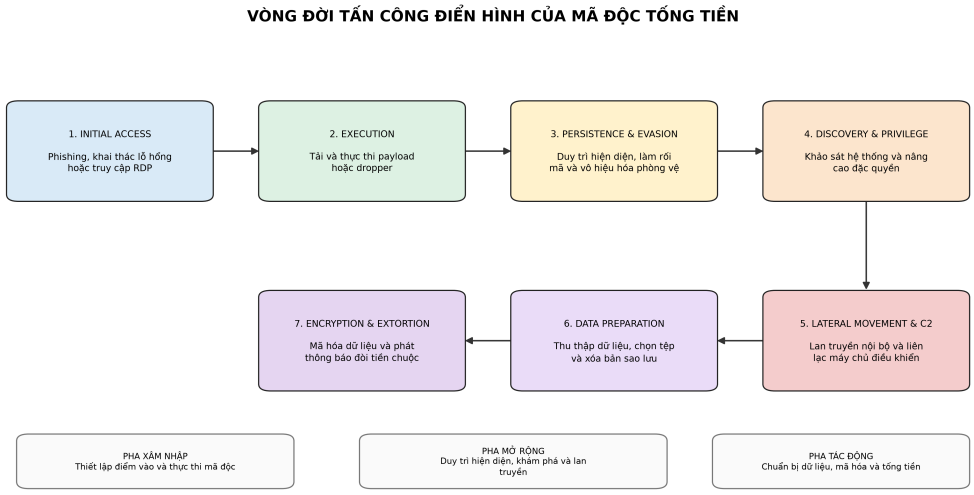
Nhóm import/export biểu diễn các tên thư viện hoặc hàm bằng băm đặc trưng nhằm giữ kích thước cố định. Cách này khác với việc tính một chuỗi MD5 ImpHash rồi coi đó là trực tiếp một vector số cho mô hình. Collision có thể làm nhiều tên ánh xạ vào cùng tọa độ; vì vậy giá trị SHAP của một bucket không mặc nhiên xác định duy nhất một API. Khi không còn metadata gốc của tệp, diễn giải cần giữ ở mức tọa độ hoặc nhóm biểu diễn thay vì gán tên API cụ thể.

Các nhóm thông tin chung, header, section và data directories bổ sung kích thước, số lượng và thuộc tính cấu trúc theo đặc tả PE/COFF [16]. Các trường này có kiểu và quan hệ phụ thuộc. Một phép thay từng chiều bằng giá trị trung bình có thể tạo vector nằm ngoài miền quan sát, dù mô hình vẫn nhận đầu vào số. Đặc tính đó là lý do cần phân biệt kiểm tra độ nhạy của mô hình trong không gian đặc trưng với biến đổi một tệp PE

thực thi hợp lệ khi đánh giá Fidelity.

2.1.3 Hành vi và chiến thuật lẩn tránh của Ransomware

Ransomware là một loại phần mềm độc hại sử dụng các thuật toán mã hóa mạnh để khóa dữ liệu của người dùng, sau đó yêu cầu tiền chuộc (ransom) để cung cấp khóa giải mã. Chu kỳ tấn công (Kill Chain) của ransomware thường trải qua 5 giai đoạn cốt lõi. Hình 2.2 minh họa chi tiết vòng đời này.



Hình 2.2: Vòng đời tấn công (Kill Chain) điển hình của mã độc tống tiền

Hình 2.2 được sử dụng như mô hình khái quát vòng đời tấn công và được tham khảo từ tài liệu minh họa của Microsoft Security [18].

Để qua mặt các hệ thống phát hiện truyền thống (dựa trên chữ ký - Signature-based), các họ ransomware hiện đại thường sử dụng các chiến thuật lẩn tránh tinh vi:

- **Đa hình (Polymorphism) và Biến hình (Metamorphism):** Thay đổi chữ ký tệp liên tục sau mỗi lần lây nhiễm.
- **Làm rối mã và Nén tệp (Obfuscation & Packing):** Che giấu luồng thực thi và các hàm API nhạy cảm bên trong các công cụ nén thương mại hoặc tự chế.
- **Tiêm tiến trình (Process Injection / Hollowing):** Chèn mã độc vào bộ nhớ của một tiến trình hệ thống hợp lệ (ví dụ: `explorer.exe` hoặc `svchost.exe`) để qua mặt các cơ chế giám sát động.

Để làm rõ hơn mức độ nguy hiểm và sự tiến hóa của các kỹ thuật lẩn tránh, Bảng 2.2 phân tích đặc trưng chiến thuật của các họ Ransomware tiêu biểu được dùng để mô tả bối cảnh đe dọa của nghiên cứu.

Bảng 2.2: Phân tích đặc trưng hành vi và kỹ thuật lẩn tránh của các họ Ransomware tiêu biểu

Họ Ransomware	**Chiến thuật mã hóa**	**Kỹ thuật lẩn tránh (Evasion Techniques)**
WannaCry	Mã hóa toàn bộ tệp, sử dụng RSA-2048 và AES-128.	Tự nhân bản qua lỗ hổng SMB (EternalBlue), không sử dụng kỹ thuật nén (Packing) quá phức tạp.
Ryuk	Mã hóa có chọn lọc, nhắm mục tiêu vào các doanh nghiệp lớn.	Tiêm tiến trình (Process Injection) vào `svchost.exe`, vô hiệu hóa các dịch vụ Antivirus trước khi mã hóa.
LockBit 3.0	Mã hóa ngắt quãng (Intermittent Encryption) cực nhanh.	Sử dụng kỹ thuật làm rối mã (Obfuscation) đa hình, mã hóa vỏ (Custom Packers), và yêu cầu mật khẩu để thực thi.
Biến thể mới	Đa dạng, phụ thuộc vào RaaS (Ransomware-as-a-Service).	Kết hợp nhiều kỹ thuật (Sleep evasion, vô hiệu hóa Volume Shadow Copy) và liên tục thay đổi chữ ký PE Header.

Sự tinh vi này đòi hỏi các hệ thống phòng thủ phải vượt ra ngoài các kỹ thuật phân tích tĩnh truyền thống, kết hợp giám sát động và ứng dụng các thuật toán Trí tuệ nhân tạo phức tạp.

2.1.4 Mô hình đe dọa và phạm vi phân tích tệp PE

Để tránh mở rộng kết luận vượt quá phạm vi thực nghiệm, luận văn xác định rõ mô hình đe dọa (threat model) cho hệ thống phát hiện. Đối tượng chính là tệp thực thi Windows PE có khả năng chứa ransomware hoặc thành phần tải ransomware. Hệ thống giả định tệp đầu vào có thể bị nén, làm rối, thay đổi thông tin header, sử dụng API nạp động hoặc thực hiện hành vi mã hóa sau một khoảng trì hoãn. Các kỹ thuật packing, obfuscation, process injection và xóa bản sao phục hồi được xem là nhóm hành vi cần quan sát vì chúng xuất hiện thường xuyên trong phân tích ransomware và mã độc Windows [1, 4, 24].

Mô hình đe dọa không giả định rằng mọi tệp entropy cao là mã độc. Một trình cài đặt hợp pháp, chương trình nén hoặc phần mềm sử dụng cơ chế bảo vệ bản quyền cũng có thể tạo section có entropy lớn. Tương tự, việc import API mã hóa không đủ để kết luận ransomware vì nhiều ứng dụng hợp pháp sử dụng mật mã. Do đó, hệ thống coi từng đặc trưng tĩnh là bằng chứng yếu và chỉ sử dụng chúng trong mô hình tổng hợp. Khi xác

suất tĩnh nằm trong vùng bất định hoặc xuất hiện tín hiệu packing mạnh, mẫu mới được chuyển sang tầng giám sát động để thu thập thêm bằng chứng hành vi.

Đối thủ được giả định có thể chỉnh sửa các trường PE không ảnh hưởng trực tiếp tới chức năng, thay đổi tên section, thêm dữ liệu đệm, nạp API động hoặc trì hoãn hành vi. Tuy nhiên, luận văn không bao phủ đầy đủ mã độc chỉ tồn tại trong bộ nhớ, mã độc kernel-mode, bootkit, firmware malware hoặc các payload không ở định dạng PE. Hệ thống cũng không được thiết kế để giải mã tệp đã bị ransomware mã hóa; mục tiêu là phát hiện và hỗ trợ ra quyết định trước hoặc trong giai đoạn hành vi đáng ngờ diễn ra.

Bảng 2.3 tóm tắt phạm vi quan sát và những trường hợp nằm ngoài phạm vi nghiên cứu. Việc công khai phạm vi này có ý nghĩa quan trọng khi đánh giá kết quả, vì một chỉ số AUC cao trên tập PE không đồng nghĩa hệ thống có thể phát hiện mọi dạng ransomware trong môi trường thực tế.

Bảng 2.3: Mô hình đe dọa và phạm vi quan sát của hệ thống

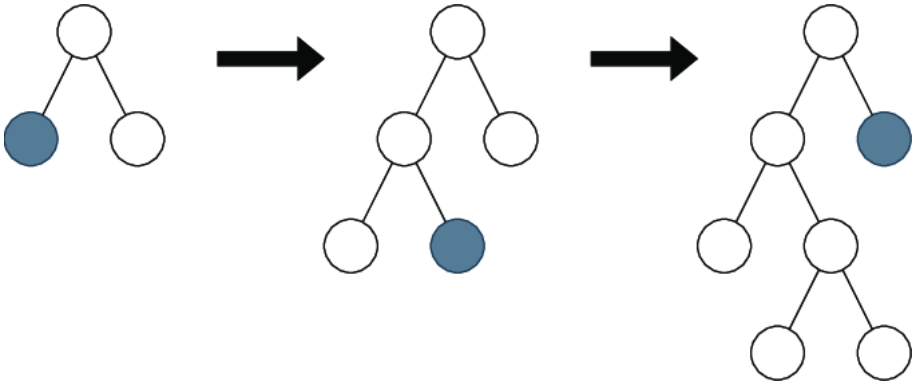
Nhóm tình huống	Phạm vi xử lý của luận văn
PE bị packing/obfuscation	Quan sát entropy, section, import và kích hoạt tầng động khi có bất định hoặc tín hiệu packing mạnh.
Nạp API động	Có thể làm suy giảm đặc trưng import; tầng động được dùng để quan sát hành vi API và file I/O.
Mã hóa hàng loạt tệp	Theo dõi tần suất đọc/ghi, đổi phần mở rộng và sử dụng API mật mã trong môi trường honeypot.
Sleep evasion / anti-analysis	Được thừa nhận là giới hạn; thời gian quan sát và user-space monitoring có thể bỏ sót hành vi trì hoãn dài.
Fileless, kernel-mode, bootkit	Ngoài phạm vi chính của luận văn; cần ETW, VMI hoặc cơ chế giám sát mức kernel trong nghiên cứu tiếp theo.

Từ mô hình đe dọa trên, có thể thấy lý do luận văn lựa chọn kiến trúc đa tầng thay vì chỉ tối ưu một bộ phân loại tĩnh. Phân tích tĩnh cung cấp khả năng sàng lọc nhanh trên số lượng lớn tệp, nhưng dễ bị ảnh hưởng bởi kỹ thuật che giấu cấu trúc. Phân tích động bổ sung thông tin hành vi nhưng chi phí cao và có thể bị né tránh. XAI được sử dụng để cung cấp bằng chứng ở cấp đặc trưng và hỗ trợ lựa chọn mẫu, trong khi khung Fidelity được dùng để kiểm tra tương đối mức độ lời giải thích bám theo hành vi của mô hình. Bốn thành phần này tạo thành cơ sở lý thuyết cho kiến trúc trình bày ở Chương 3.

2.2 Học máy và Trí tuệ nhân tạo có thể giải thích (XAI) trong An toàn thông tin

2.2.1 Mô hình học máy LightGBM trong phân loại mã độc

LightGBM (Light Gradient Boosting Machine) là một khung học máy dạng cây phân cấp, tối ưu hóa dựa trên thuật toán Gradient Boosting Decision Tree (GBDT). Khác với các thuật toán GBDT truyền thống phát triển cây theo chiều rộng (level-wise), LightGBM phát triển cây theo chiều sâu (leaf-wise) nhằm tối ưu hóa việc giảm thiểu hàm mất mát. Hình 2.3 minh họa sự khác biệt giữa hai chiến lược phát triển cây này.



Hình 2.3: So sánh chiến lược phát triển cây Leaf-wise của LightGBM và Level-wise truyền thống

Hình 2.3 được biên tập theo tài liệu LightGBM về chiến lược phát triển cây leaf-wise [12, 17].

Theo cách xây dựng hàm mục tiêu của các mô hình gradient tree boosting dựa trên khai triển Taylor bậc hai [5, 12], hàm mục tiêu tại vòng lặp thứ t có thể được viết dưới dạng xấp xỉ:

$$Obj^{(t)} \approx \sum_{i=1}^{n} \left[g_i f_t(x_i) + \frac{1}{2} h_i f_t^2(x_i) \right] + \Omega(f_t) \tag{2.2}$$

Trong đó, g_i và h_i lần lượt là đạo hàm bậc nhất (gradient) và bậc hai (Hessian) của hàm mất mát đối với dự đoán ở bước trước đó. Thành phần $\Omega(f_t)$ là hàm chuẩn hóa (regularization term) để kiểm soát độ phức tạp của cây, tránh hiện tượng quá khớp (overfitting).

Bằng cách sử dụng hai kỹ thuật cốt lõi là Lấy mẫu dựa trên Gradient (GOSS - Gradient-based One-Side Sampling) và Ghép bó đặc trưng độc quyền (EFB - Exclusive Feature Bundling), LightGBM có khả năng xử lý tập dữ liệu hàng triệu tệp PE với hàng nghìn chiều đặc trưng trong thời gian cực ngắn. Mặc dù đạt hiệu năng phân loại xuất sắc, cấu trúc quyết định qua hàng trăm cây của LightGBM lại tạo ra một ”hộp đen” (Black-box) phi tuyến tính, làm mất đi tính minh bạch cần thiết trong an ninh mạng.

2.2.2 Trí tuệ nhân tạo có thể giải thích (Explainable AI - XAI) và TreeSHAP

Sự thiếu minh bạch của các mô hình học máy hộp đen tạo ra rào cản lớn trong lĩnh vực An toàn thông tin, nơi các quyết định dự đoán sai có thể làm tăng tải xác minh cảnh báo hoặc làm gián đoạn quy trình vận hành. XAI được nghiên cứu nhằm cung cấp thông tin giải thích cho quyết định của mô hình, nhưng các khảo sát cũng nhấn mạnh rằng khả năng diễn giải cho con người và mức độ trung thực với hành vi nội tại của mô hình là hai tiêu chí cần được phân biệt [10, 27]. Vì vậy, luận văn sử dụng XAI theo hai mục đích: hỗ trợ chuyên gia hiểu đặc trưng ảnh hưởng đến dự đoán và cung cấp tín hiệu cho quá trình chọn mẫu, đồng thời xây dựng một khung kiểm chứng định lượng riêng.

SHAP (SHapley Additive exPlanations) xây dựng lời giải thích cộng tính dựa trên giá trị Shapley trong lý thuyết trò chơi hợp tác [14]. Giá trị Shapley ϕ_i của đặc trưng thứ i được tính theo công thức:

$$\phi_i = \sum_{S \subseteq F \setminus \{i\}} \frac{|S|!(|F| - |S| - 1)!}{|F|!} \left[f_x(S \cup \{i\}) - f_x(S) \right] \tag{2.3}$$

Trong đó, F là tập hợp tất cả các đặc trưng, S là một tập con của các đặc trưng không chứa i, và $f_x(S)$ là mô hình dự đoán chỉ sử dụng tập đặc trưng S.

Việc lựa chọn SHAP thay vì các phương pháp giải thích khác (như LIME hay Grad-CAM) được dựa trên các phân tích đánh giá kỹ thuật. Bảng 2.4 trình bày sự so sánh giữa các phương pháp XAI phổ biến trên nền tảng dữ liệu dạng bảng (Tabular Data).

Bảng 2.4: Đánh giá và so sánh các phương pháp Giải thích mô hình (XAI)

Phương pháp	**Ưu điểm chính**	**Hạn chế**	**Độ phù hợp (PE Data)**
LIME	Giải thích cục bộ độc lập với mô hình; chi phí phụ thuộc số perturbation.	Dễ bị bất ổn định, giải thích có thể thay đổi với cùng một điểm dữ liệu nếu nhiễu cao.	Trung bình
Grad-CAM	Trực quan hóa vùng ảnh ảnh hưởng tới dự đoán của CNN.	Không áp dụng được cho mô hình dạng cây (Tree-based) hoặc dữ liệu dạng bảng.	Thấp
TreeSHAP	Có cơ sở tiên đề rõ ràng cho mô hình giải thích cộng tính và tính toán hiệu quả với mô hình dạng cây.	Yêu cầu sức mạnh tính toán cao đối với các mô hình quá lớn.	Rất cao

Đối với các mô hình dạng cây như LightGBM, thuật toán **TreeSHAP** được áp dụng để đưa độ phức tạp tính toán từ cách liệt kê trực tiếp các tập con đặc trưng sang thuật toán cho cây có độ phức tạp $O(TLD^2)$ [15], với T là số cây, L là số lá tối đa, và D là độ sâu tối đa của cây. Giá trị SHAP giúp chuyên gia an ninh mạng nhận diện các đặc trưng có đóng góp lớn vào quyết định của mô hình, từ đó hỗ trợ quá trình xác minh cảnh báo. Tuy nhiên, độ tin cậy thực sự của những lời giải thích này (XAI Fidelity) khi đối mặt với dữ liệu mã độc bị làm rối vẫn là một vấn đề cần được kiểm chứng định lượng.

Nền tảng tiên đề của giá trị SHAP:

Ưu điểm của TreeSHAP so với một số phương pháp giải thích xấp xỉ như LIME là có cơ sở Shapley rõ ràng và thỏa mãn các tính chất local accuracy, missingness và consistency của lớp mô hình giải thích cộng tính như trình bày bởi Lundberg và Lee [14]. Tuy nhiên, các tính chất này không đồng nghĩa với quan hệ nhân quả tuyệt đối giữa đặc trưng và hành vi mã độc; vì vậy luận văn vẫn cần kiểm chứng định lượng độ phù hợp của lời giải thích:

- **Tiên đề 1: Tính chính xác cục bộ (Local Accuracy):** Tổng các giá trị giải thích của từng đặc trưng cộng với giá trị kỳ vọng nền (Base value ϕ_0) phải bằng giá trị đầu ra $f(x)$ trên thang đo được giải thích. Trong thực nghiệm, thang đó là raw score/log-odds; không cộng các đóng góp này trực tiếp thành xác suất.

$$f(x) = \phi_0 + \sum_{i=1}^{M} \phi_i x'_i \tag{2.4}$$

- **Tiên đề 2: Tính khuyết thiếu (Missingness):** Nếu biến chỉ báo hiện diện x'_i trong biểu diễn giải thích bằng 0, đóng góp tương ứng phải bằng 0. Điều này không có nghĩa một giá trị số $x_i = 0$ của đặc trưng PE thì SHAP bằng 0.

$$x'_i = 0 \implies \phi_i = 0 \tag{2.5}$$

- **Tiên đề 3: Tính nhất quán (Consistency):** Nếu kiến trúc của mô hình thay đổi sao cho một đặc trưng i có ảnh hưởng lớn hơn hoặc bằng đến kết quả dự đoán (so với mô hình cũ), thì giá trị SHAP ϕ_i của nó không được phép giảm. Điều kiện về đóng góp biên phải thỏa với mọi tập con S không chứa i. Gọi $f_x(S)$ là giá trị của trò chơi giải thích tại mẫu x khi xét tập đặc trưng S, và N là tập tất cả đặc trưng:

$$\begin{aligned} f'_x(S \cup \{i\}) - f'_x(S) \geq f_x(S \cup \{i\}) - f_x(S), \\ \forall S \subseteq N \setminus \{i\} \quad \implies \quad \phi_i(f', x) \geq \phi_i(f, x). \end{aligned} \tag{2.6}$$

Ba tính chất này tạo thành cơ sở lý thuyết để luận văn xây dựng Khung đánh giá định lượng Fidelity ở Chương 3, đồng thời là lý do cần kiểm chứng thực nghiệm thay vì chỉ

dựa vào trực quan hóa.

2.2.3 Giới hạn của XAI trong phân tích mã độc

XAI không tự động biến một mô hình học máy thành hệ thống có quan hệ nhân quả hoặc hoàn toàn đáng tin cậy. Một bộ giải thích hậu kiểm có thể phản ánh chính xác cách mô hình sử dụng đặc trưng nhưng mô hình gốc vẫn học phải tương quan giả. Ví dụ, nếu một họ ransomware trong tập huấn luyện thường có giá trị `TimeDateStamp` bất thường, TreeSHAP có thể gán mức đóng góp lớn cho trường này. Lời giải thích khi đó trung thực với mô hình, nhưng chưa đủ để kết luận thời gian biên dịch là nguyên nhân gây ra hành vi ransomware. Sự khác biệt giữa fidelity và causality là một giới hạn quan trọng của XAI [10, 27].

Một vấn đề khác là sự phụ thuộc giữa các đặc trưng PE. Các trường như `SizeOfImage`, `SectionAlignment`, số lượng section và kích thước từng section không hoàn toàn độc lập. Khi một phương pháp giải thích thay đổi hoặc che một đặc trưng riêng lẻ, tổ hợp mới có thể rời khỏi phân phối dữ liệu hợp lệ. Điều này làm cho phép thử perturbation hoặc masking có nguy cơ đo tác động của dịch chuyển phân phối thay vì đo mức độ quan trọng thực sự của đặc trưng. Vì lý do đó, khung Fidelity của luận văn sử dụng giá trị nền lấy từ dữ liệu huấn luyện trong phép che từng chiều đã đo, đồng thời thảo luận masking theo nhóm như hướng phát triển cần kiểm tra ở Chương 3.

Độ ổn định của lời giải thích cũng là một thách thức. Hai mẫu PE có cấu trúc gần nhau có thể nhận các vector SHAP khác biệt nếu chúng nằm ở hai phía của nhiều ngưỡng chia cây. Ngược lại, hai mẫu có vector SHAP tương đồng chưa chắc có hành vi thực thi giống nhau nếu một số API được nạp động hoặc payload chỉ xuất hiện sau khi giải nén. Vì vậy, luận văn không sử dụng SHAP như bằng chứng duy nhất để kết luận mã độc. SHAP được xem là một nguồn tín hiệu bổ sung cho chuyên gia và cho thuật toán Học tích cực.

Từ góc độ an toàn hệ thống, lời giải thích cũng có thể trở thành bề mặt tấn công. Đối thủ có thể chỉnh sửa các đặc trưng ít ảnh hưởng tới chức năng nhằm làm thay đổi phân bố giá trị SHAP, che giấu đặc trưng thực sự quan trọng hoặc khiến hệ thống ưu tiên sai mẫu trong vòng lặp Học tích cực. Các khảo sát về học máy phát hiện mã độc đã chỉ ra rằng tính đối kháng và thay đổi phân phối dữ liệu là thách thức lâu dài của các mô hình học máy trong an toàn thông tin [9, 25]. Do phạm vi luận văn tập trung vào kiến trúc và kiểm chứng ban đầu, bài toán thao túng lời giải thích được ghi nhận là hướng nghiên cứu tiếp theo.

Tóm lại, TreeSHAP được lựa chọn vì phù hợp với LightGBM và có cơ sở toán học rõ ràng, không phải vì lời giải thích của nó mặc nhiên đúng trong mọi trường hợp. Cách tiếp cận của luận văn là sử dụng TreeSHAP, sau đó kiểm tra Faithfulness, Consistency và Contrastive trên cùng pipeline. Đây là cơ sở trực tiếp cho khung Fidelity trình bày ở

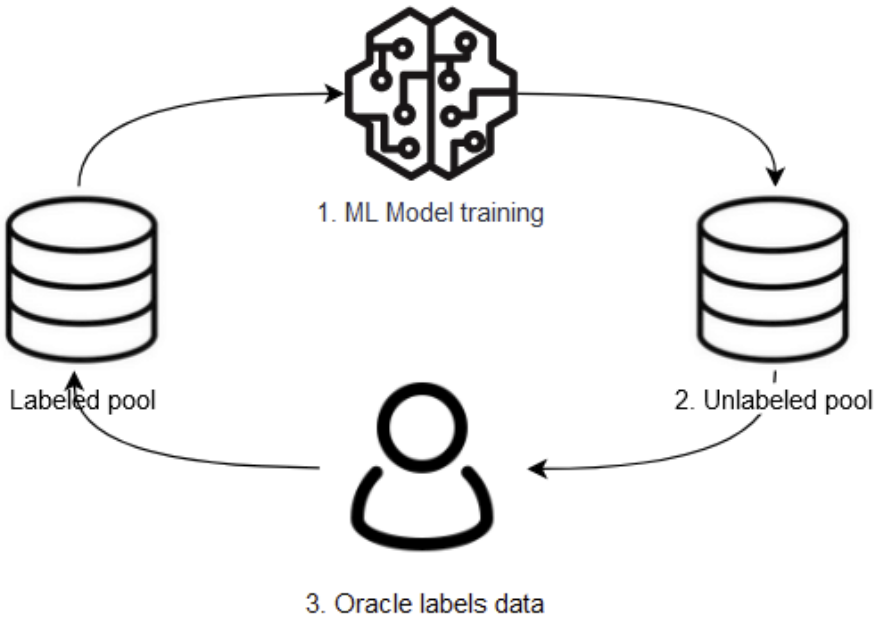
Chương 3.

2.3 Học tích cực (Active Learning) trong môi trường dữ liệu bất cân xứng

2.3.1 Tổng quan về phương pháp Học tích cực

Trong lĩnh vực an toàn thông tin, đặc biệt là phát hiện mã độc, dữ liệu luôn có tính bất cân xứng cao. Số lượng các tệp tin an toàn (benign) thường áp đảo số lượng mã độc (malware), và trong nhóm mã độc, các mẫu đã biết (known malware) lại áp đảo các mẫu chưa được quan sát. Việc gán nhãn thủ công cho hàng triệu tệp tin thực thi để phục vụ huấn luyện mô hình Học máy có giám sát (Supervised Learning) là bất khả thi về mặt thời gian và chi phí đối với các chuyên gia phân tích (Oracles).

Học tích cực (Active Learning - AL) là một nhánh của Học máy giải quyết bài toán này bằng cách cho phép mô hình chủ động lựa chọn các mẫu dữ liệu có giá trị thông tin cao nhất từ tập dữ liệu chưa gán nhãn (unlabeled pool U). Hình 2.4 thể hiện quy trình khép kín của phương pháp học này.



Hình 2.4: Quy trình cốt lõi của hệ thống Học tích cực dựa trên tập mẫu (Pool-based Active Learning)

Hình 2.4 do tác giả tổng hợp theo mô hình pool-based active learning trong tài liệu của Settles [22].

Theo mô hình pool-based active learning trong tổng quan của Settles [22], bài toán chọn mẫu có thể biểu diễn bằng việc tìm mẫu x^* tối đa hóa một hàm hữu ích $\phi(x)$:

$$x^* = \arg\max_{x \in U} \phi(x) \tag{2.7}$$

2.3.2 Các chiến lược trích mẫu truyền thống và hạn chế

Các chiến lược truy vấn dựa trên độ bất định như least confidence, margin sampling và entropy sampling được tổng hợp rộng rãi trong tài liệu Học tích cực [22]. Với bài toán phân loại nhị phân Ransomware/Benign, gọi $\hat{y}$ là nhãn dự đoán có xác suất cao nhất, ba thước đo cơ bản được viết như sau:

- **Độ tin cậy thấp nhất (Least Confidence):** Chọn mẫu mà mô hình ít tự tin nhất vào nhãn dự đoán của nó:

$$\phi_{LC}(x) = 1 - P(\hat{y}|x) \tag{2.8}$$

- **Khoảng lề (Margin Sampling):** Chọn mẫu có khoảng cách xác suất giữa nhãn có khả năng nhất ($\hat{y}_1$) và nhãn có khả năng thứ hai ($\hat{y}_2$) nhỏ nhất:

$$\phi_M(x) = 1 - \big(P(\hat{y}_1|x) - P(\hat{y}_2|x)\big) \tag{2.9}$$

- **Độ hỗn loạn xác suất (Entropy-based):** Lấy mẫu có độ hỗn loạn Shannon của phân phối đầu ra lớn nhất:

$$\phi_{ENT}(x) = -\sum_i P(y_i|x) \log_2 P(y_i|x) \tag{2.10}$$

Độ bất định dự đoán không trực tiếp xác định giá trị mà một nhãn mới sẽ mang lại sau cập nhật mô hình. Một tệp hợp lệ bị packing có thể nằm gần ranh giới; nhãn của mẫu đó vẫn có thể hữu ích để giảm báo động nhầm. Ngược lại, các mẫu nhiễu hoặc ngoài phân phối có thể chiếm nhiều truy vấn mà không cải thiện khả năng khái quát. Vì vậy, luận văn xem thông tin SHAP là giả thuyết bổ sung cho điểm chọn mẫu, chứ không mặc nhiên coi mọi mẫu bất định là lãng phí hoặc mọi mẫu có xung đột giải thích là hữu ích. Giá trị của lựa chọn này được đánh giá bằng đối chứng cùng ngân sách với Random và Uncertainty.

2.3.3 Mất cân bằng lớp, concept drift và thiên lệch truy vấn

Trong phát hiện mã độc, Học tích cực không chỉ chịu ảnh hưởng của số lượng mẫu chưa gán nhãn mà còn chịu tác động của mất cân bằng lớp và concept drift. Concept drift mô tả tình huống quan hệ giữa dữ liệu đầu vào và nhãn thay đổi theo thời gian; trong an toàn thông tin, sự xuất hiện của packer mới, chuỗi API mới hoặc chiến thuật mã hóa ngắt quãng có thể làm thay đổi phân phối đặc trưng mà mô hình đã học. Các nghiên cứu về concept drift nhấn mạnh rằng mô hình trên luồng dữ liệu cần có cơ chế phát hiện hoặc thích nghi với thay đổi phân phối thay vì giả định dữ liệu độc lập và đồng phân phối theo thời gian [8].

Nếu tập chưa gán nhãn bị chi phối bởi mẫu benign, chiến lược random sampling có thể tiêu tốn phần lớn ngân sách gán nhãn vào các mẫu dễ. Ngược lại, uncertainty sampling có xu hướng tập trung mạnh quanh biên quyết định hiện tại. Điều này tạo ra query bias: tập mẫu được gán nhãn mới không còn đại diện ngẫu nhiên cho phân phối ban đầu mà phản ánh ưu tiên của chính mô hình đang được cải thiện. Query bias không nhất thiết là sai, vì mục tiêu của Active Learning là chọn mẫu hữu ích; tuy nhiên, nếu không kiểm soát, mô hình có thể bỏ qua các vùng dữ liệu hiếm mà nó dự đoán sai với độ tự tin cao.

Trong bài toán ransomware, hiện tượng dự đoán sai với độ tự tin cao đặc biệt đáng chú ý. Một biến thể được đóng gói bằng packer chưa xuất hiện trong tập huấn luyện có thể có cấu trúc PE giống phần mềm hợp pháp và nhận $P(y = \text{malware}|x)$ thấp. Nếu hệ thống chỉ chọn mẫu gần xác suất 0,5, mẫu này sẽ không được đưa vào hàng đợi. Luận văn đặt giả thuyết rằng cấu trúc SHAP có thể cung cấp thêm tín hiệu: nhiều đặc trưng quan trọng cùng đẩy dự đoán theo hai hướng trái ngược hoặc phân tán mạnh là dấu hiệu mô hình đang sử dụng một cấu trúc quyết định phức tạp, ngay cả khi xác suất đầu ra không nằm đúng giữa biên phân loại.

Một vấn đề khác là chi phí oracle không đồng nhất. Phân tích một tệp PE đơn giản có thể hoàn thành nhanh từ import table và strings, trong khi mẫu bị packing có thể cần giải nén, theo dõi động và đối chiếu nhiều nguồn. Vì vậy, tối ưu Học tích cực theo số lượng mẫu chưa chắc đồng nghĩa tối ưu theo thời gian chuyên gia. Trong phạm vi luận văn, ngân sách được mô hình hóa theo số mẫu để giữ kịch bản đánh giá rõ ràng. Hướng mở rộng hợp lý là xây dựng cost-sensitive active learning, trong đó hàm truy vấn cân bằng giá trị thông tin và chi phí phân tích dự kiến của oracle.

Các phân tích trên dẫn đến hai yêu cầu đối với chiến lược chọn mẫu của luận văn. Thứ nhất, các tín hiệu tổng hợp phải được chuẩn hóa trước khi cộng để tránh một đại lượng có thang đo lớn chi phối toàn bộ điểm truy vấn. Thứ hai, kết quả phải được so sánh với uncertainty-only và random sampling dưới cùng ngân sách. Hai yêu cầu này được cụ thể hóa trong thuật toán XAI-Guided Active Learning ở Chương 3 và kịch bản đánh giá ở Chương 4.

2.4 Các nghiên cứu liên quan và Khe hổng nghiên cứu (Research Gap)

2.4.1 Tổng hợp các công trình nghiên cứu nổi bật

Các hướng nghiên cứu liên quan đến đề tài có thể được nhóm thành ba dòng chính.

- **Phát hiện dựa trên phân tích tĩnh:** Các nghiên cứu sử dụng đặc trưng PE, byte n-gram, import API và mô hình học máy như Random Forest, Gradient Boosting hoặc LightGBM cho thấy hiệu quả cao khi xử lý tập dữ liệu lớn. Bộ dữ liệu SOREL-20M của Harang và Rudd là một ví dụ quan trọng trong hướng tiếp cận này, nhấn

mạnh khả năng huấn luyện mô hình trên quy mô hàng triệu tệp [11]. Tuy nhiên, phân tích tĩnh dễ bị ảnh hưởng bởi packing, obfuscation và API được nạp động.

- **Phân tích động và giám sát hành vi:** Các hệ thống sandbox, honeypot và giám sát API giúp phát hiện hành vi mã hóa, xóa bản sao phục hồi, sửa registry hoặc quét thư mục; phân tích hành vi là hướng được sử dụng rộng rãi trong nghiên cứu ransomware [4, 13]. Điểm mạnh của hướng này là quan sát hành vi thực thi, nhưng nhược điểm là độ trễ cao và có thể bị né tránh bởi kỹ thuật anti-analysis, sleep evasion hoặc phát hiện môi trường ảo hóa.
- **XAI và Học tích cực trong an toàn thông tin:** SHAP, LIME và các phương pháp giải thích hậu kiểm đã được dùng để trực quan hóa quyết định của mô hình [10, 14, 20]. Học tích cực thường được sử dụng để giảm chi phí gán nhãn bằng cách chọn các mẫu bất định. Tuy nhiên, ít nghiên cứu khai thác trực tiếp cấu trúc của lời giải thích như một tiêu chí chọn mẫu và cũng ít nghiên cứu định lượng độ phù hợp của lời giải thích trong miền dữ liệu PE.

Bảng 2.5: So sánh các nghiên cứu liên quan với hệ thống đề xuất của luận văn

Hướng nghiên cứu	**Phương pháp tiêu biểu**	**Ưu điểm**	**Giới hạn còn tồn tại**
Harang và cộng sự (SOREL-20M)	LightGBM trên đặc trưng PE	Khai thác dữ liệu quy mô lớn, hiệu năng cao trong phân tích tĩnh.	Khả năng giải thích và xử lý mẫu bị packing/obfuscation còn cần bổ sung bằng cơ chế khác.
Phân tích động / Honeypot	Giám sát I/O và API nhạy cảm	Quan sát hành vi thực thi, hữu ích với mẫu mới.	Độ trễ cao, phụ thuộc môi trường thực thi và dễ bị kỹ thuật anti-analysis.
XAI trong phát hiện mã độc	SHAP/LIME hậu kiểm	Hỗ trợ diễn giải quyết định mô hình.	Thường dừng ở trực quan hóa, chưa gắn chặt với vòng lặp học và kiểm chứng định lượng.
Active Learning truyền thống	Uncertainty, margin, entropy sampling	Giảm chi phí gán nhãn so với học thụ động.	Chủ yếu dựa trên xác suất đầu ra, chưa khai thác xung đột trong lời giải thích.
Luận văn đề xuất	**Static + Dynamic + XAI-guided AL + Fidelity**	**Kết hợp tín hiệu tĩnh/động, dùng XAI để hỗ trợ chọn mẫu và đánh giá lời giải thích.**	**Cần được kiểm chứng thêm trên tập dữ liệu lớn hơn, nhiều seed hơn và nhiều baseline hơn.**

2.4.2 Khe hổng nghiên cứu (Research Gap)

Từ các công trình liên quan, luận văn xác định ba khoảng trống chính:

- **Fusion Gap:** Nhiều hệ thống khai thác phân tích tĩnh hoặc phân tích động riêng lẻ, nhưng chưa làm rõ cơ chế dung hợp thích nghi giữa hai nguồn tín hiệu trong điều kiện có độ trễ và độ tin cậy khác nhau.
- **Active Learning Gap:** Các chiến lược chọn mẫu thường dựa trên xác suất dự đoán. Luận văn đặt giả thuyết rằng cấu trúc lời giải thích, đặc biệt là xung đột giữa nhóm đặc trưng ủng hộ hai nhãn, có thể cung cấp thêm tín hiệu để chọn mẫu có giá trị thông tin cao.
- **Fidelity Gap:** XAI trong phát hiện mã độc thường được dùng để minh họa, nhưng

thiếu bộ chỉ số định lượng theo ngữ cảnh PE để đánh giá mức độ lời giải thích phản ánh hành vi của mô hình.

Ba khoảng trống này là cơ sở để luận văn xây dựng kiến trúc đa tầng ở Chương 3. Tuy vậy, luận văn không xem các chỉ số đề xuất là chuẩn phổ quát; chúng được sử dụng như một khung đánh giá tương đối và cần tiếp tục được đối chiếu với các thước đo hiện có trong XAI.

2.4.3 Định vị nghiên cứu và tiêu chí thiết kế

Từ tổng quan trên, luận văn không đặt mục tiêu thay thế hoàn toàn các hệ thống sandbox hoặc xây dựng một bộ phân loại PE mới từ đầu. Trọng tâm của nghiên cứu là cách tổ chức và liên kết bốn thành phần đã có nền tảng độc lập gồm mô hình cây tăng cường, giải thích SHAP, giám sát hành vi và Học tích cực. Tính mới được xem xét ở mức tích hợp có định nghĩa thuật toán: cổng bất định quyết định khi nào kích hoạt tầng động; PID cập nhật trọng số sau khi có hai xác suất; cấu trúc SHAP tham gia trực tiếp vào điểm truy vấn Học tích cực; và lời giải thích được đánh giá bằng các phép đo trên vector PE có thảo luận về tính hợp lệ của masking thay vì chỉ hiển thị trên dashboard.

Việc lựa chọn LightGBM xuất phát từ đặc tính dữ liệu dạng bảng, nhiều trường số và đặc trưng thưa của PE. LightGBM được thiết kế để xử lý hiệu quả dữ liệu nhiều chiều bằng GOSS và EFB [12]. TreeSHAP được chọn vì có thuật toán chuyên biệt cho mô hình dạng cây và nền tảng giải thích cộng tính [14]. Học tích cực được lựa chọn do chi phí gán nhãn mã độc cao và nhu cầu ưu tiên một phần mẫu chưa biết [22]. PID được sử dụng như một bộ điều phối trọng số thực nghiệm; luận văn thừa nhận đây không phải lựa chọn duy nhất và vì vậy đưa fixed-weight fusion vào thiết kế đối chứng ở Chương 4.

Bảng 2.6 tổng hợp tiêu chí thiết kế rút ra từ khe hổng nghiên cứu. Các tiêu chí này được sử dụng như cầu nối giữa Chương 2 và kiến trúc ở Chương 3.

Bảng 2.6: Tiêu chí thiết kế hệ thống rút ra từ tổng quan nghiên cứu

Tiêu chí	Yêu cầu	Thành phần đáp ứng
Chi phí phân tích	Không chạy sandbox cho mọi mẫu; ưu tiên sàng lọc nhanh.	LightGBM và cổng bất định.
Bổ sung bằng chứng hành vi	Có cơ chế quan sát I/O và API khi tín hiệu tĩnh chưa đủ.	Watchdog Honeypot.
Minh bạch quyết định	Cung cấp đặc trưng đóng góp cho từng dự đoán.	TreeSHAP.
Thích nghi dữ liệu mới	Ưu tiên mẫu giàu thông tin dưới ngân sách gán nhãn giới hạn.	XAI-Guided Active Learning.
Kiểm chứng lời giải thích	Không đánh đồng biểu đồ dễ hiểu với fidelity.	FF, EC, CF; thảo luận quy ước OFS.
Tái lập	Phân biệt rõ độ trễ từng tầng, tham số, seed và chính sách masking.	Đặc tả thực nghiệm và phụ lục.

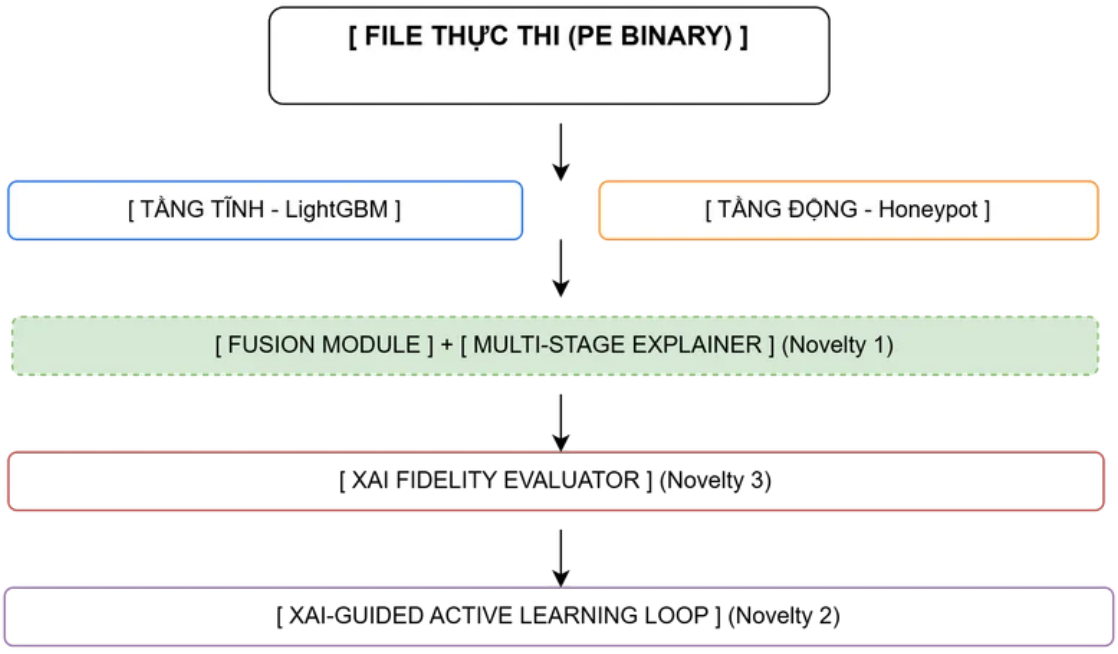
Từ các tiêu chí trên, kiến trúc đề xuất được xây dựng theo nguyên tắc "tách quyết định kích hoạt khỏi quyết định dung hợp". Đây là điểm logic quan trọng: $P_{dynamic}$ chỉ tồn tại sau khi giám sát động đã chạy, do đó không thể dùng chênh lệch $P_{dynamic} - P_{static}$ để quyết định ban đầu có kích hoạt honeypot hay không. Cổng bất định xử lý quyết định thứ nhất; PID chỉ xử lý quyết định thứ hai sau khi hai nguồn tín hiệu sẵn sàng. Chương 3 trình bày chi tiết luồng dữ liệu này.

Chương 3
KIẾN TRÚC HỆ THỐNG PHÁT HIỆN RANSOMWARE ĐA TẦNG TÍCH HỢP XAI

Trên cơ sở lý thuyết và khe hổng nghiên cứu được phân tích ở Chương 2, chương này trình bày kiến trúc hệ thống đề xuất. Luồng xử lý được tổ chức thành các tầng gồm phân tích tĩnh, cổng bất định, giám sát động, dung hợp thích nghi, giải thích và vòng lặp Học tích cực. Các công thức kế thừa từ tài liệu trước được trích dẫn tại vị trí sử dụng; những đại lượng như Directional Entropy, điểm truy vấn tổng hợp và OFS được xác định rõ là định nghĩa thực nghiệm do luận văn đề xuất.

3.1 Tổng quan kiến trúc hệ thống đề xuất

Kiến trúc hệ thống phát hiện ransomware được thiết kế theo nguyên tắc phòng thủ nhiều tầng và tách biệt rõ các quyết định vận hành. Đầu vào của hệ thống là tệp thực thi Windows PE. Tệp được trích xuất đặc trưng tĩnh, đưa qua LightGBM để sinh xác suất P_{static} và đồng thời được TreeSHAP giải thích ở mức đặc trưng. Cổng bất định kiểm tra xác suất tĩnh cùng một số tín hiệu packing để xác định mẫu nào cần chuyển sang giám sát động. Khi tầng động hoàn thành, hệ thống nhận $P_{dynamic}$ và sử dụng cơ chế PID-Fusion để cập nhật trọng số giữa hai nguồn xác suất. Hình 3.1 minh họa luồng dữ liệu tổng thể.



Hình 3.1: Sơ đồ kiến trúc tổng thể của Hệ thống phát hiện Ransomware đa tầng tích hợp XAI

3.1.1 Các phân hệ chức năng

Phân hệ phát hiện đa tầng thực hiện sàng lọc nhanh và thu thập bằng chứng hành vi. Mô hình LightGBM xử lý vector đặc trưng PE để cung cấp dự đoán ban đầu. Nếu mẫu nằm ngoài vùng bất định và không có tín hiệu packing mạnh, hệ thống có thể sử dụng kết quả tĩnh nhằm giảm chi phí. Nếu mẫu nằm trong vùng bất định, Thiết kế chuyển mẫu sang một môi trường giám sát hành vi. Watchdog hỗ trợ quan sát sự kiện hệ thống tệp; việc theo dõi API nhạy cảm hoặc can thiệp vào cơ chế phục hồi cần instrumentation bổ sung, không được suy ra từ file I/O đơn lẻ. Sau khi có hai xác suất, PID-Fusion mới được thực hiện. Thiết kế này bảo đảm $P_{dynamic}$ không được sử dụng trước khi tầng động thực sự chạy.

Phân hệ giải thích và kiểm chứng sử dụng TreeSHAP để tạo vector đóng góp đặc trưng cho từng dự đoán. Các giá trị SHAP được hiển thị trên dashboard để hỗ trợ chuyên gia xác minh cảnh báo và đồng thời được sử dụng làm đầu vào cho hai tác vụ khác. Tác vụ thứ nhất là tính Directional Entropy và SHAP Variance cho Học tích cực. Tác vụ thứ hai là tính các chỉ số Faithfulness, Consistency và Contrastive trong khung Fidelity. Luận văn không giả định rằng một biểu đồ SHAP đẹp đồng nghĩa lời giải thích đúng; vì vậy quá trình sinh giải thích và quá trình đánh giá giải thích được tách thành hai bước.

Phân hệ Học tích cực quản lý tập chưa gán nhãn, hàng đợi truy vấn và quá trình tái huấn luyện. Mỗi mẫu được chấm điểm theo độ bất định, xung đột hướng của SHAP và độ phân tán giải thích. Sau bước chuẩn hóa, các mẫu có điểm cao được đưa vào hàng đợi để chuyên gia gán nhãn. Trong thí nghiệm offline, mô hình được huấn luyện lại sau mỗi batch nhãn, sau đó đánh giá trên validation và test theo giao thức cố định. Kiểm soát phiên bản và rollback là yêu cầu thiết kế cho vận hành, chưa thuộc phạm vi thực nghiệm xác nhận.

3.1.2 Luồng dữ liệu và trạng thái hệ thống

Luồng xử lý một tệp được chia thành bảy trạng thái logic: `RECEIVED`, `STATIC_ANALYZED`, `DYNAMIC_QUEUED`, `DYNAMIC_ANALYZED`, `FUSED`, `EXPLAINED` và `AL_CANDIDATE`. Không phải mọi tệp đều đi qua toàn bộ trạng thái. Một mẫu có xác suất tĩnh đủ rõ có thể kết thúc tại `EXPLAINED`; mẫu bất định sẽ chuyển sang hàng đợi động, sau đó mới được dung hợp. Việc biểu diễn trạng thái giúp log hệ thống phản ánh chính xác tầng nào đã chạy và tránh diễn giải sai độ trễ.

Bảng 3.1 mô tả dữ liệu đầu vào, dữ liệu đầu ra và điều kiện chuyển trạng thái. Các trạng thái này mô tả giao diện tích hợp được đề xuất; artifacts của hai thí nghiệm offline ở Chương 4 được lưu theo checkpoint và chỉ số dòng.

Bảng 3.1: Trạng thái logic và dữ liệu trao đổi giữa các phân hệ

Trạng thái	Dữ liệu chính	Điều kiện/chức năng
RECEIVED	Hash, đường dẫn tạm, metadata	Tệp PE được tiếp nhận và kiểm tra định dạng.
STATIC_ANALYZED	Vector 2.381 chiều, P_{static}, $\Phi(x)$	Hoàn thành trích xuất PE, dự đoán LightGBM và TreeSHAP.
DYNAMIC_QUEUED	ID phiên, lý do kích hoạt	P_{static} nằm trong vùng bất định hoặc có tín hiệu packing mạnh.
DYNAMIC_ANALYZED	Trace hành vi, file I/O, $P_{dynamic}$	Honeypot hoàn thành cửa sổ quan sát.
FUSED	w_s, w_d, P_{final}	PID cập nhật trọng số sau khi có hai xác suất.
EXPLAINED	Top-k SHAP, FF/EC/CF khi đánh giá batch	Cung cấp bằng chứng đặc trưng và thông tin kiểm chứng.
AL_CANDIDATE	S_{AL}, lý do truy vấn	Mẫu đủ điều kiện tham gia hàng đợi gán nhãn.

Khi triển khai trực tuyến, cần phân biệt mô hình đang phục vụ M_t với mô hình ứng viên M_{t+1}. Một chính sách vận hành có thể yêu cầu kiểm tra chất lượng trên validation trước khi thay phiên bản và giữ khả năng rollback. Đây là hướng tổ chức hệ thống; thí nghiệm AL của luận văn học lại theo lịch cố định, không thực hiện chọn checkpoint bằng test hoặc đánh giá hiệu quả của một cơ chế triển khai MLOps.

3.2 Khung giải thích đa tầng (Multi-Stage XAI Framework)

3.2.1 Phân tích tĩnh và tín hiệu giám sát động

Nhánh tĩnh sử dụng vector đặc trưng PE theo lược đồ EMBER phiên bản 2, gồm 2.381 chiều [2]. Vector được đưa vào LightGBM để sinh điểm $P_{static} \in [0, 1]$ cho lớp dương; TreeSHAP cung cấp các đóng góp đặc trưng $\Phi = [\phi_1, \ldots, \phi_n]$ đối với đầu ra mô hình. Trong đợt đánh giá trên tập con hiện có, đầu vào là các vector đã được trích xuất. Số chiều phù hợp với lược đồ EMBER không tự xác nhận nguồn gốc của từng mẫu hoặc nhãn dương dành riêng cho ransomware; phạm vi dữ liệu được trình bày trong chương thực nghiệm.

Bảng 3.2: Các nhóm đặc trưng của lược đồ EMBER phiên bản 2

Nhóm đặc trưng	**Số chiều**	**Nội dung biểu diễn**
Byte histogram	256	Phân bố tần suất các giá trị byte.
Byte–entropy histogram	256	Thống kê kết hợp giá trị byte và entropy cục bộ.
Strings	104	Thống kê chuỗi ký tự và một số mẫu chuỗi.
General file information	10	Kích thước và các thuộc tính tổng quát.
Header information	62	Các trường và thuộc tính của header PE.
Section information	255	Thống kê kích thước, entropy và thuộc tính section.
Imports	1.280	Biểu diễn băm thông tin thư viện và hàm nhập.
Exports	128	Biểu diễn băm tên hàm xuất.
Data directories	30	Kích thước và địa chỉ của các data directory.
Tổng	**2.381**	

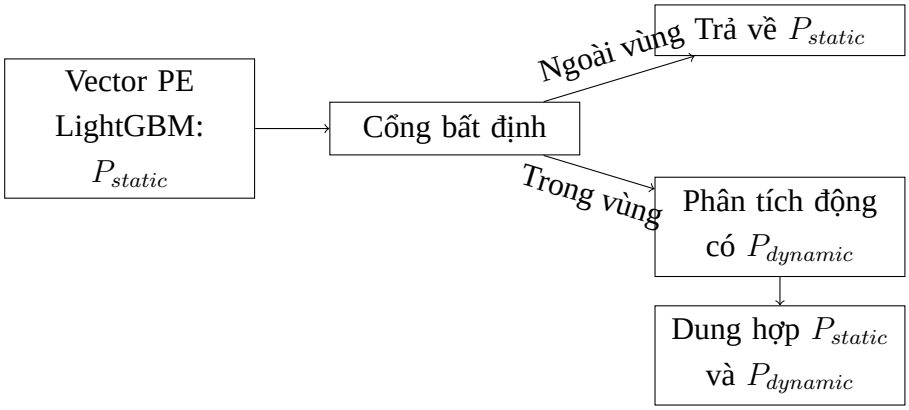
Nhánh động được đề xuất để bổ sung quan sát hành vi mà đặc trưng tĩnh không thể hiện trực tiếp. Bảng 3.3 liệt kê các nguồn tín hiệu có thể sử dụng. Cần phân biệt bộ giám sát sự kiện hệ thống tệp với công cụ thu thập lời gọi API: Watchdog trong mã hiện có theo dõi sự kiện tệp, không tự cung cấp cơ chế giám sát mọi API Windows. Việc chuyển các sự kiện thành $P_{dynamic}$ cần một quy tắc chấm điểm được xác định và kiểm chứng trên dữ liệu có nhãn; không xem điểm quy tắc là xác suất đã được hiệu chuẩn nếu chưa đánh giá hiệu chuẩn.

Bảng 3.3: Nguồn tín hiệu hành vi trong thiết kế nhánh động

Nhóm hành vi	**Quan sát cần thu thập**	**Điều kiện sử dụng**
Thay đổi hệ thống tệp	Sửa, đổi tên, xóa tệp; thay đổi entropy.	Giám sát sự kiện tệp và gắn sự kiện với phiên chạy mẫu.
Hoạt động mã hóa	Các lời gọi như `CryptEncrypt` cùng ngữ cảnh truy cập tệp.	Cần nguồn API trace; một lời gọi mã hóa riêng lẻ không xác định mã độc.
Thay đổi cơ chế phục hồi	Tiến trình gọi công cụ xóa bản sao phục hồi hoặc chỉnh sửa cấu hình.	Cần trace tiến trình/hệ thống phù hợp, ngoài sự kiện tệp của Watchdog.

Trong kiến trúc đề xuất, **cổng bất định** quyết định mẫu nào cần bổ sung phân tích động. Một chính sách cơ sở chuyển mẫu có $P_{static} \in [\theta_{low}, \theta_{high}]$ sang nhánh động và trả về điểm tĩnh cho các mẫu còn lại. Các điều kiện bổ sung, chẳng hạn tín hiệu packing,

cần được đặc tả và đánh giá riêng. Ngưỡng cổng phải được chọn trên tập xác thực. Hình 3.2 làm rõ rằng nhánh chỉ dùng phân tích tĩnh không đi qua phép dung hợp hai nguồn.



Hình 3.2: Luồng xử lý đề xuất với cổng bất định đặt trước nhánh động

3.2.2 Cơ chế trọng số thích nghi dựa trên PID

PID được lựa chọn như một cấu trúc cập nhật trọng số có trạng thái, kế thừa ba thành phần tỷ lệ, tích phân và vi phân [3]. Động cơ của thành phần tỷ lệ là phản ứng với bất đồng hiện tại; thành phần tích phân tổng hợp bất đồng qua các bước; thành phần vi phân phản ứng với thay đổi của bất đồng. Đây là các giả thuyết thiết kế cần kiểm chứng, không phải bảo đảm rằng nguồn nhận trọng số lớn hơn luôn dự đoán đúng. Đặc biệt, sai lệch giữa hai điểm mô hình không phải sai số so với nhãn thật.

Để thống nhất ký hiệu với triển khai tham chiếu trong `src/pid_fusion.py`, luận văn dùng sai lệch theo chiều tĩnh trừ động và cập nhật *trọng số tĩnh*. Tại bước quan sát k:

$$e_k = P_{static,k} - P_{dynamic,k}, \tag{3.1}$$

$$S_k = S_{k-1} + e_k, \qquad d_k = e_k - e_{k-1}, \tag{3.2}$$

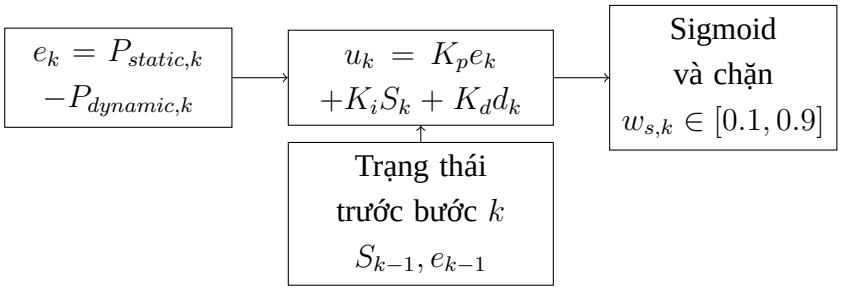
$$u_k = K_p e_k + K_i S_k + K_d d_k, \tag{3.3}$$

$$w_{s,k} = \text{clip}(\sigma(u_k), 0.1, 0.9)\,, \quad \sigma(z) = \frac{1}{1+\exp(-z)}, \tag{3.4}$$

$$w_{d,k} = 1 - w_{s,k}, \tag{3.5}$$

$$P_{final,k} = w_{s,k} P_{static,k} + w_{d,k} P_{dynamic,k}. \tag{3.6}$$

Trạng thái khởi tạo là $S_0 = 0$ và $e_0 = 0$. Các hệ số mặc định trong mã tham chiếu là $(K_p, K_i, K_d) = (0.85, 0.12, 0.35)$; chúng không được coi là cấu hình tối ưu đã được xác nhận bởi đợt thực nghiệm hiện tại. Hình 3.3 mô tả đúng vai trò của khối cập nhật trọng số; không có phản hồi nhãn thật để điều chỉnh sai số phát hiện trong khối này.



Hình 3.3: Khối cập nhật trọng số có trạng thái của triển khai PID-Fusion tham chiếu

Thuật toán 3.1 mô tả riêng bước dung hợp khi hai tín hiệu đã sẵn sàng. Việc tạo ra điểm động và điều phối cổng bất định thuộc các khối khác của kiến trúc; không được suy ra từ việc hàm dung hợp chạy thành công.

Listing 3.1: Cập nhật PID-Fusion theo triển khai tham chiếu

```
# Input: p_static, p_dynamic; state: integral, prev_error
# Initial state for a new declared sequence: 0.0, 0.0
error = p_static - p_dynamic
integral = integral + error
derivative = error - prev_error
control = kp * error + ki * integral + kd * derivative
w_static = clip(sigmoid(control), 0.1, 0.9)
p_final = w_static * p_static + (1 - w_static) * p_dynamic
prev_error = error
return p_final, integral, prev_error
```

Triển khai này là cập nhật theo *bước quan sát*; không có tham số thời gian Δt tường minh, giới hạn tích phân hay bộ lọc đạo hàm. Vì vậy không đồng nhất S_k với tích phân theo giây của tín hiệu liên tục. Dạng có Δt, anti-windup hoặc lọc đạo hàm là các mở rộng cần được cài đặt và đánh giá riêng. Chặn trọng số đầu ra tại Công thức (3.4) không thay thế giới hạn tích phân, vì trạng thái S_k vẫn có thể tăng khi sai lệch cùng dấu kéo dài.

3.2.3 Tính chất toán học và phạm vi diễn giải

Tính chất tổ hợp lồi. Giả sử các điểm đầu vào hữu hạn và nằm trong $[0, 1]$. Từ $w_{s,k} \in [0.1, 0.9]$ và $w_{d,k} = 1 - w_{s,k}$, hai trọng số không âm và có tổng bằng một. Do đó:

$$\min(P_{static,k}, P_{dynamic,k}) \leq P_{final,k} \leq \max(P_{static,k}, P_{dynamic,k}). \tag{3.7}$$

Đây là bảo đảm về miền giá trị của phép dung hợp. Nó không chứng minh đầu ra đã được hiệu chuẩn, FPR giảm, AUC tăng hoặc hệ thống có ổn định vòng kín theo lý thuyết điều khiển.

Một phân tích riêng thành phần P làm rõ giới hạn này. Đặt $K_i = K_d = 0$, $e =$

$P_{static} - P_{dynamic}$ và xét miền mà phép chặn trọng số chưa hoạt động. Khi đó:

$$P_{final} = \frac{P_{static} + P_{dynamic}}{2} + \frac{e}{2} \tanh\left(\frac{K_p e}{2}\right). \tag{3.8}$$

Với $K_p \geq 0$, hạng thứ hai không âm. Thành phần P vì thế thiên về điểm lớp dương lớn hơn so với trung bình hai nguồn, chứ chưa xác định được nguồn nào đáng tin hơn. Xu hướng này có thể tăng khả năng phát hiện một số mẫu nhưng cũng có thể tạo thêm báo động nhầm. Các thành phần I và D làm trọng số phụ thuộc lịch sử; không có suy luận từ Công thức (3.8) rằng PID đầy đủ luôn tăng hoặc giảm một chỉ số phân loại cụ thể.

Ý nghĩa của lịch sử cũng cần được đặc tả: k có thể là các thời điểm trong cùng một phiên quan sát hoặc các phiên theo thứ tự đã xác định. Nếu mỗi bước là một tệp độc lập, sai phân giữa hai bước không mặc nhiên thể hiện biến đổi hành vi của cùng một đối tượng. Do đó, đánh giá thực nghiệm phải ghi lại thứ tự và quy tắc reset trạng thái; kiểm tra đảo thứ tự là một cách nhận biết mức nhạy với lựa chọn này.

3.2.4 Độ phức tạp và các điều kiện kiểm chứng

Bước cập nhật tại Công thức (3.6) cần số phép toán và số biến trạng thái không đổi, nên có chi phí tính toán và bộ nhớ $O(1)$ mỗi bước sau khi hai điểm đầu vào đã có. Kết quả này không xác định độ trễ theo mili-giây. Thời gian trích đặc trưng, sinh TreeSHAP, quan sát hành vi, chờ hàng đợi và ghi nhật ký cần được đo tách biệt nếu đánh giá độ trễ đầu cuối.

Bảng 3.4: Điều kiện diễn giải và kiểm chứng PID-Fusion

Vấn đề	**Trạng thái tham chiếu**	**Kiểm chứng cần có**
Tích lũy sai lệch	Có tổng S_k; chưa chặn tích phân.	Mức bão hòa và độ nhạy với thời lượng chuỗi; đánh giá riêng nếu thêm anti-windup.
Phụ thuộc thứ tự	Có sai phân và trạng thái trước đó.	Cùng thứ tự giữa các đối chứng; kiểm tra đảo thứ tự và reset.
Trọng số bị chặn	$w_s \in [0.1, 0.9]$.	Hiệu chuẩn và sai số phân loại; miền giá trị không thay thế các phép đo này.
Chất lượng nguồn động	Hàm dung hợp nhận điểm đầu vào.	Điểm động thực của cùng mẫu, nhãn độc lập và cửa sổ quan sát thống nhất.
Chi phí vận hành	$O(1)$ riêng phép dung hợp.	Đo thời gian dung hợp và đầu cuối bằng các mốc thời gian tách biệt.

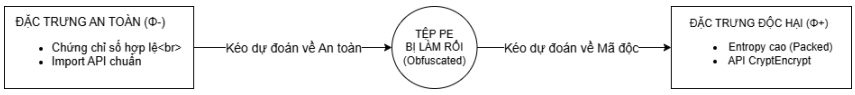
Đóng góp ở mức phương pháp là cách tổ chức dung hợp có trạng thái sau cổng bất định. Để xác nhận giá trị phát hiện của lựa chọn này, cần so sánh với trọng số cố định và các biến thể P, PI trên cùng tín hiệu đầu vào. Phần đánh giá tiếp theo trình bày phạm vi bằng chứng hiện có và các đối chứng cần thiết; không suy diễn hiệu quả toàn hệ thống từ tính hợp lệ của công thức dung hợp.

3.3 Học tích cực hướng dẫn bởi XAI (XAI-Guided Active Learning)

Các chiến lược Học tích cực truyền thống thường sử dụng độ bất định dựa trên xác suất dự đoán làm tiêu chí chọn mẫu. Cách tiếp cận này đơn giản và hiệu quả trong nhiều bài toán, nhưng với dữ liệu mã độc bị làm rối, xác suất đầu ra không phải lúc nào cũng phản ánh đầy đủ nguyên nhân khiến mô hình khó ra quyết định. Luận văn đề xuất bổ sung thông tin từ lời giải thích SHAP để nhận diện các mẫu có xung đột đặc trưng cao.

3.3.1 Định lượng xung đột đặc trưng (Directional Entropy)

Với một mẫu tệp thực thi x, mô hình TreeSHAP xuất ra tập hợp các giá trị giải thích $\Phi(x) = \{\phi_1, \phi_2, ..., \phi_m\}$. Ta chia $\Phi(x)$ thành hai tập: tập đóng góp tăng raw score của lớp dương (Φ^+) và tập đóng góp giảm raw score (Φ^-). Sự xung đột giữa hai nhóm này được mô phỏng trực quan trong Hình 3.4.



Hình 3.4: Minh họa khái niệm Xung đột đặc trưng (Directional Entropy) thông qua hai luồng lực đẩy SHAP

Từ vector SHAP của Lundberg và Lee [14], luận văn **đề xuất** gom các giá trị theo dấu và chuẩn hóa tổng độ lớn tuyệt đối. Tỷ lệ đóng góp của hai nhóm được định nghĩa là p^+ và p^-:

$$p^+ = \frac{\sum_{\phi_i \in \Phi^+} |\phi_i|}{\sum_{j=1}^{m} |\phi_j|}, \quad p^- = \frac{\sum_{\phi_i \in \Phi^-} |\phi_i|}{\sum_{j=1}^{m} |\phi_j|} \tag{3.9}$$

Dựa trên entropy Shannon [23], luận văn **đề xuất** đại lượng Directional Entropy cho hai nhóm đóng góp trái dấu như sau:

$$H_{dir}(x) = -(p^+ \log_2 p^+ + p^- \log_2 p^-) \tag{3.10}$$

Khi tổng độ lớn SHAP bằng 0, quy ước $H_{dir} = 0$; sử dụng $0 \log_2 0 = 0$ ở biên. TreeSHAP trong thí nghiệm được tính ở thang log-odds của mô hình hiện tại, không phải trực tiếp ở thang xác suất. Giá trị H_{dir} cao cho thấy hai nhóm đặc trưng kéo dự đoán theo hai hướng khác nhau. Đây là tín hiệu cho thấy mẫu có thể hữu ích trong vòng

lặp gán nhãn, nhưng không được xem là bằng chứng độc lập để kết luận một mẫu là ransomware.

3.3.2 Đánh giá độ phân tán giải thích (SHAP Variance)

Bên cạnh xung đột hướng, luận văn sử dụng phương sai thống kê của vector SHAP như một chỉ báo mô tả độ phân tán đóng góp. Đại lượng σ^2_{SHAP} được **định nghĩa trong pipeline của luận văn** như sau:

$$\sigma^2_{SHAP}(x) = \frac{1}{m}\sum_{i=1}^{m}(\phi_i - \bar{\phi})^2 \tag{3.11}$$

Do các thành phần $U(x)$, $H_{dir}(x)$ và $\sigma^2_{SHAP}(x)$ có thể nằm trên các thang đo khác nhau, luận văn áp dụng chuẩn hóa min–max trên tập ứng viên tại từng vòng. Công thức chuẩn hóa được sử dụng trong pipeline là:

$$\widehat{z}(x) = \begin{cases} \dfrac{z(x) - \min_{u\in U} z(u)}{\max_{u\in U} z(u) - \min_{u\in U} z(u)}, & \max z > \min z, \\ 0, & \max z = \min z. \end{cases} \tag{3.12}$$

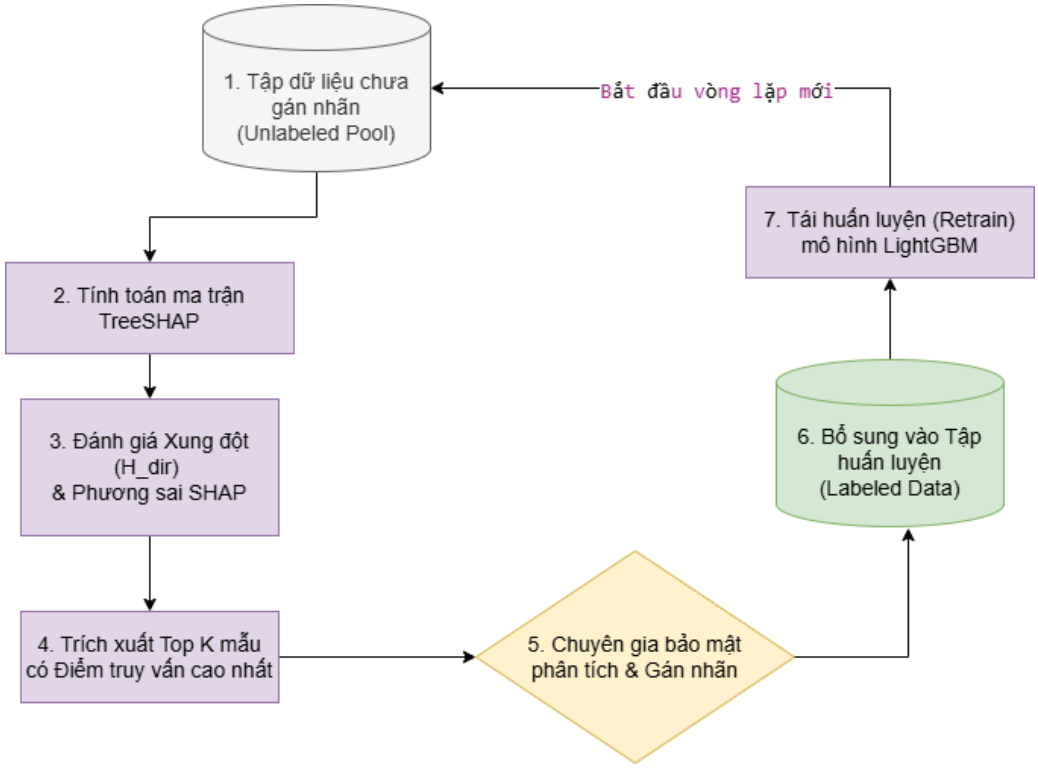
Các cực trị được lấy trên pool U ở vòng hiện tại; tín hiệu hằng được ánh xạ về 0. Biến thiên của vector SHAP ở đây là đặc trưng của điểm truy vấn, không được đồng nhất với ước lượng bất định nhận thức của mô hình.

3.3.3 Chiến lược chọn mẫu và tối ưu chi phí

Trên nền tảng pool-based active learning [22], luận văn **đề xuất** điểm truy vấn tổng hợp S_{AL} kết hợp ba tín hiệu đã chuẩn hóa: độ bất định $\widehat{U}(x)$, Xung đột đặc trưng $\widehat{H}_{dir}(x)$ và Phương sai SHAP $\widehat{\sigma}^2_{SHAP}(x)$:

$$S_{AL}(x) = \alpha\widehat{U}(x) + \beta\widehat{H}_{dir}(x) + \gamma\widehat{\sigma}^2_{SHAP}(x), \quad \alpha+\beta+\gamma = 1 \tag{3.13}$$

Quy trình vận hành của hệ thống Học tích cực được thiết kế theo dạng vòng lặp có chuyên gia trong quy trình (Human-in-the-loop), được thể hiện qua Hình 3.5 và Thuật toán 3.2.



Hình 3.5: Lưu đồ vòng lặp thuật toán Học tích cực hướng dẫn bởi bộ giải thích XAI

Listing 3.2: Thuật toán Học tích cực hướng dẫn bởi XAI

```
Input: Tap gan nhan L, tap chua gan nhan U, mo hinh M, ngan sach truy van
   B
Output: Mo hinh M sau khi cap nhat

1. Khoi tao M ← Train(L)
2. While B > 0 do:
3.     For x in U:
4.         p(x) ← M(x)
5.         Φ(x) ← TreeSHAP(M, x)
6.         U(x) ← 1 − |2p(x) − 1|
7.         H_dir(x) ← Tinh Directional Entropy
8.         σ²(x) ← Tinh SHAP Variance
9.     End For
10.    Chuan hoa U, H_dir, σ² ve [0, 1]
11.    S_AL(x) = αÛ(x) + βĤ_dir(x) + γσ̂²(x)
12.    X_query ← Top-K mau co diem S_AL cao nhat
13.    Y_query ← Oracle(X_query)
14.    L ← L ∪ (X_query, Y_query)
15.    U ← U \ X_query
16.    M ← Retrain(L)
17.    B ← B − K
18. End While
```

19. **return** M

3.3.4 Kiểm soát thiên lệch truy vấn và chi phí tính toán

Điểm truy vấn có thể ưu tiên một nhóm cấu trúc PE lặp lại, dẫn tới lãng phí ngân sách khi pool chứa nhiều mẫu gần trùng. Trong thí nghiệm của Chương 4, dữ liệu được kiểm tra trùng vector hoàn toàn và không phát hiện cặp trùng. CSV không có hash tệp hoặc metadata họ, nên runner không áp dụng loại trùng SHA-256, quota theo họ hay lựa chọn đa dạng bằng cosine. Mọi đối chứng nhận cùng pool; một mẫu đã truy vấn bị loại khỏi pool của chính lần chạy đó. Sự công bằng về ngân sách được kiểm soát bằng cùng tập khởi tạo, số vòng và kích thước batch.

Các phương pháp dựa trên SHAP trong thí nghiệm tính giải thích trên toàn bộ pool ở từng vòng, có kích thước từ 1.000 xuống 600 trước năm truy vấn. Mô hình được huấn luyện lại trên nhãn tích lũy và TreeSHAP được tính lại từ mô hình này. Runner không dùng bộ giải thích lưu từ checkpoint trước, không tự chuyển sang dữ liệu mô phỏng khi có lỗi. Thời gian tính điểm được đo riêng với thời gian huấn luyện để xác định phần chi phí bổ sung do SHAP.

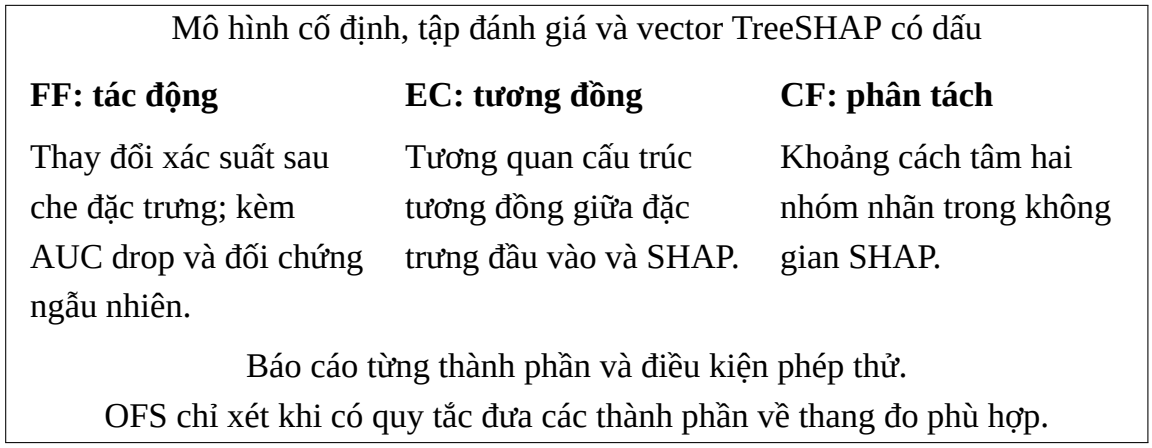
Với pool lớn hơn, lọc một tập ứng viên bằng tiêu chí rẻ trước khi tính TreeSHAP và kiểm soát độ đa dạng trong batch là những lựa chọn triển khai có thể xem xét. Tuy nhiên, các lựa chọn này làm thay đổi chính sách truy vấn và chưa được đưa vào các số liệu của Chương 4. Nếu áp dụng, cần một đối chứng cùng ngân sách tính toán để phân biệt lợi ích chọn mẫu với lợi ích sàng lọc.

Bảng 3.5: Quy ước lựa chọn mẫu trong thí nghiệm AL

Yếu tố	**Thiết lập được sử dụng**
Pool và ngân sách	Cùng chỉ số khởi tạo theo seed, năm batch, mỗi batch 100 mẫu.
Định nghĩa tín hiệu	$U(x) = 1 - 2\|p(x) - 0,5\|$; entropy theo độ lớn SHAP hai dấu; phương sai SHAP có dấu.
Chuẩn hóa	Min–max trên pool hiện tại; tín hiệu hằng bằng 0.
Cắt bỏ thành phần	Giữ trọng số tương đối của các thành phần còn lại, rồi chuẩn hóa tổng bằng 1.
Trạng thái mô hình	Huấn luyện mới trên toàn bộ nhãn tích lũy sau mỗi batch; SHAP dùng mô hình hiện tại.
Trùng điểm truy vấn	Ưu tiên chỉ số dòng nhỏ hơn; kiểm tra không chọn lại dòng đã gán nhãn.

3.4 Khung đánh giá XAI định lượng và điều kiện áp dụng cho đặc trưng PE

Đóng góp thứ ba của luận văn là đặc tả một khung đánh giá tương đối chất lượng giải thích trên dữ liệu dạng bảng PE. Khung kế thừa tinh thần kiểm tra fidelity và độ nhạy của lời giải thích trong nghiên cứu XAI [27], đồng thời xác định phép che đặc trưng, phép đo tương đồng và các điều kiện diễn giải trong bài toán đang xét. Các công thức FF, EC, CF và quy tắc tổng hợp OFS dưới đây là lựa chọn thực nghiệm của luận văn; chúng không được xem là một bộ chuẩn đã được xác nhận cho mọi bài toán mã độc. Mục tiêu là kiểm tra sự phù hợp giữa giải thích và hành vi của mô hình, không suy ra quan hệ nhân quả của hành vi ransomware.



Hình 3.6: Khung đánh giá giải thích và điều kiện sử dụng điểm tổng hợp

3.4.1 Phép che đặc trưng và độ trung thực (Faithfulness – FF)

Gọi $p(x)$ là xác suất dự đoán nhãn 1 và $\Phi(x) = [\phi_1(x), \ldots, \phi_d(x)]$ là vector TreeSHAP của mô hình. Trong thực nghiệm được báo cáo, TreeSHAP được tính bằng tùy chọn `pred_contrib` của LightGBM trên thang điểm thô (log-odds). Tổng các đóng góp cùng giá trị nền được kiểm tra khớp với điểm thô; các độ thay đổi sau che lại được đo trên thang xác suất. Hai thang đo này không đồng nhất.

Với mỗi mẫu, tập $T_k(x)$ gồm k chiều có $|\phi_j(x)|$ lớn nhất. Mỗi chiều được chọn được thay bằng trung bình μ_j^{train} tính *chỉ trên tập huấn luyện*; các chiều còn lại giữ nguyên:

$$x_j^{(k)} = \begin{cases} \mu_j^{train}, & j \in T_k(x), \\ x_j, & j \notin T_k(x). \end{cases} \tag{3.14}$$

Thực nghiệm dùng $k \in \{10, 25, 50\}$. Với mỗi k, đối chứng chọn đều k chiều không hoàn lại cho từng mẫu và lặp 20 lần. Hai cách chọn có cùng số chiều được yêu cầu che; số tọa độ thực sự thay đổi và độ lớn thay đổi của vector không nhất thiết bằng nhau. Trung bình train là một baseline tái lập được, nhưng không bảo đảm vector sau che thỏa mãn

cấu trúc PE.

Độ thay đổi xác suất và chỉ số FF ban đầu của luận văn được giữ tường minh:

$$\Delta P_k(x) = p(x) - p(x^{(k)}), \qquad FF_k = \frac{1}{N}\sum_{i=1}^{N}\frac{|\Delta P_k(x_i)|}{p(x_i)+\epsilon}, \quad \epsilon = 10^{-12}. \tag{3.15}$$

FF không bị chặn ở 1 và có thể lớn khi $p(x_i)$ gần 0. Vì vậy, thực nghiệm báo cáo giá trị thô, không diễn giải FF như xác suất lời giải thích đúng và không tự cắt FF để tạo một điểm tổng hợp. Để đọc kết quả thuận tiện hơn, luận văn báo cáo thêm hai đại lượng khác, không đổi tên chúng thành FF:

$$M_k = \frac{1}{N}\sum_{i=1}^{N}|\Delta P_k(x_i)|, \tag{3.16}$$

$$D_k^{AUC} = \text{AUC}(y, p(X)) - \text{AUC}(y, p(X^{(k)})). \tag{3.17}$$

M_k đo thay đổi xác suất tuyệt đối trung bình; D_k^{AUC} đo thay đổi khả năng xếp hạng trên cùng tập mẫu và có thể âm. Do top-k được chọn theo trị tuyệt đối SHAP, việc che có thể làm xác suất nhãn 1 tăng hoặc giảm. Đối chứng ngẫu nhiên giúp kiểm tra liệu thứ hạng SHAP có xác định các chiều ảnh hưởng đến mô hình tốt hơn lựa chọn đều hay không; nó chưa thay thế so sánh với một bộ giải thích cạnh tranh.

3.4.2 Độ nhất quán (Consistency – EC)

EC mô tả mức đồng biến của cấu trúc tương đồng mẫu giữa không gian đặc trưng và không gian giải thích. Với mỗi chiều, đặt $z_j(x) = (x_j - \mu_j^{train})/s_j^{train}$; nếu độ lệch chuẩn train bằng 0 thì dùng mẫu số 1. Định nghĩa $S_X(i,j) = \cos(z(x_i), z(x_j))$ và $S_\Phi(i,j) = \cos(\Phi(x_i), \Phi(x_j))$, trong đó SHAP giữ dấu. Giá trị cosine với một vector có chuẩn bằng 0 được quy ước bằng 0, phù hợp triển khai dùng trong thí nghiệm. Gọi $\text{vec}_\triangle$ lấy phần tam giác trên và bỏ đường chéo, khi đó:

$$EC = r\left(\text{vec}_\triangle(S_X), \text{vec}_\triangle(S_\Phi)\right), \tag{3.18}$$

với r là hệ số tương quan Pearson [19]. Khi phương sai của một vector so sánh bằng 0, hệ số không xác định và phải được ghi nhận thay vì gán thành một kết quả có lợi. Khi xác định, $EC \in [-1, 1]$. EC cao không tự chứng minh lời giải thích trung thực: các mẫu gần nhau theo biểu diễn PE cũng có thể nằm ở hai phía biên quyết định. Các cặp trong ma trận chia sẻ mẫu, nên không áp dụng trực tiếp kiểm định Pearson giả định từng cặp độc lập. Phép đo này khác với tiên đề consistency của SHAP và khác phép thử ổn định bằng nhiễu Gaussian.

3.4.3 Độ tương phản (Contrastive – CF) và giới hạn của OFS

CF mô tả mức phân tách hai nhóm nhãn trong không gian giải thích. Gọi C_1 và C_0 là trung bình vector SHAP của các mẫu có nhãn tương ứng trong tập đánh giá. Quy tắc được dùng là:

$$CF = \frac{\|C_1 - C_0\|_2}{\max_{x \in X_{test}} \|\Phi(x)\|_2 + \epsilon}. \tag{3.19}$$

Mẫu số là chuẩn lớn nhất của *một vector SHAP mẫu*, không phải chuẩn lớn nhất của hai tâm nhóm. Theo bất đẳng thức tam giác, mỗi tâm có chuẩn không vượt chuẩn mẫu lớn nhất, nên $0 \leq CF \leq 2$. Không có bảo đảm CF nằm trong $[0, 1]$. Nhãn chỉ được sử dụng ở bước đánh giá hậu kiểm; CF không tham gia dự đoán. Một CF lớn thể hiện tính phân biệt theo công thức này, chưa chứng minh các đặc trưng được giải thích là nguyên nhân của nhãn hoặc hành vi mã độc.

Luận văn xem xét trung bình điều hòa như một quy tắc tổng hợp có điều kiện. Nếu ba điểm $\widetilde{FF}, \widetilde{EC}, \widetilde{CF}$ đã được đưa về các thang đo dương có ý nghĩa so sánh bằng quy tắc xác định trước, có thể đặt:

$$OFS = \frac{3\widetilde{FF}\,\widetilde{EC}\,\widetilde{CF}}{\widetilde{FF}\,\widetilde{EC} + \widetilde{EC}\,\widetilde{CF} + \widetilde{CF}\,\widetilde{FF}}. \tag{3.20}$$

Quy tắc này hạn chế sự bù trừ của thành phần lớn đối với thành phần nhỏ, nhưng lựa chọn phép tổng hợp không tự tạo tính hợp lệ cho các thành phần. FF thô không bị chặn, EC có thể âm và CF có miền khác; vì vậy không thay trực tiếp các số thô vào công thức rồi diễn giải như một chuẩn chất lượng. Phần thực nghiệm của luận văn báo cáo riêng FF, EC, CF, M_k và D_k^{AUC}; chưa tính OFS khi chưa xác lập và kiểm tra quy tắc đưa về cùng thang đo. Việc cắt tùy ý các điểm về $[0, 1]$ có thể làm mất thông tin và thay đổi thứ hạng.

3.4.4 Sự phù hợp với PE và phạm vi kiểm chứng

Đặc trưng PE gồm số đếm, giá trị liên tục, cờ và các vector băm có quan hệ cấu trúc. Trung bình một cột có thể không còn là số đếm nguyên; thay từng cột có thể phá quan hệ giữa kích thước, địa chỉ và section. Tương tự, thay một vùng ảnh hoặc thêm nhiễu pixel cũng có thể tạo dữ liệu ngoài phân phối, nhưng không cung cấp một quy tắc bảo toàn cấu trúc tệp PE. Vì vậy, việc chuyển nguyên tắc đánh giá XAI sang PE cần quy định riêng đối tượng biến đổi và giới hạn của phép thử.

Bảng 3.6 phân biệt phép thử đã thực hiện với các điều kiện cần phát triển để đánh giá sâu hơn tính phù hợp PE. Phần sau là hướng hoàn thiện của khung, chưa được tính là kết quả kiểm chứng trong luận văn.

Bảng 3.6: Phạm vi phép che đã thực hiện và điều kiện cần bổ sung cho PE

Khía cạnh	**Phép thử đã thực hiện**	**Điều kiện cần bổ sung**
Giá trị nền	Trung bình từng cột từ train; test không tham gia ước lượng.	Giá trị tham chiếu theo kiểu dữ liệu; kiểm tra miền và số nguyên của đặc trưng đếm.
Quan hệ giữa chiều	Che riêng từng chiều được SHAP hoặc random chọn.	Nhóm phụ thuộc của section, header và directory; so sánh cùng ngân sách biến đổi.
Vector import/export	Chịu cùng phép thay bằng trung bình như các cột khác.	Kiểm tra ý nghĩa bucket và cấu trúc thưa; chưa suy ra một import hợp lệ từ giá trị trung bình.
Tính hợp lệ PE	Đánh giá trên vector số, không sửa tệp nhị phân.	Kiểm tra ràng buộc vector; nếu cần kết luận ở mức tệp thì phải kiểm chứng riêng tệp sau biến đổi.

Đóng góp của khung trong phạm vi đã kiểm chứng là một giao thức đo có đối chứng, định nghĩa rõ và đầu ra truy vết được. Một giải thích trung thực với mô hình vẫn có thể phản ánh tương quan giả mà mô hình đã học. Do đó, kết quả không được dùng để khẳng định đồng thời tính đúng của bộ phát hiện, quan hệ nhân quả và tính hợp lệ thực thi của mẫu PE sau biến đổi.

Chương 4
TRIỂN KHAI THỰC NGHIỆM VÀ ĐÁNH GIÁ KẾT QUẢ

Chương này đánh giá các thành phần của kiến trúc bằng những phép so sánh có phạm vi xác định. Thực nghiệm định lượng gồm Học tích cực hướng dẫn bởi XAI trên 5 outer folds và đánh giá Fidelity cùng độ ổn định của TreeSHAP trên 25 mô hình. Dữ liệu EMBER tĩnh được đối chiếu theo định danh mẫu và hash vector đặc trưng. Đối với PID, chương phân tích cơ chế và thiết kế đối chứng cần thiết trên tín hiệu tĩnh–động ghép cặp. Mỗi kết quả được gắn với dữ liệu, cấu hình và dấu vết phép đo; kết luận về từng thành phần được phân biệt với hiệu quả của toàn hệ thống.

4.1 Dữ liệu, môi trường và giao thức đánh giá

4.1.1 Phạm vi và nguồn dữ liệu đã xác minh

Phần định lượng của chương gồm hai thực nghiệm: so sánh các chiến lược Học tích cực (AL) ở cùng ngân sách nhãn và kiểm tra Fidelity cùng độ ổn định của TreeSHAP. Cả hai dùng các mô hình được huấn luyện mới và lưu cấu hình, phân hoạch, dự đoán cùng đầu ra trung gian để tái kiểm. Dung hợp PID được phân tích riêng ở Mục 4.2; kết quả tĩnh trong chương không được dùng thay cho bằng chứng tĩnh–động.

Dữ liệu gồm 2.000 mẫu trích từ tập kiểm thử EMBER 2018, mỗi mẫu có 2.381 đặc trưng tĩnh theo schema EMBER v2 [2]. Trong đó có 1.500 mẫu benign và 500 mẫu malware. Tệp dữ liệu có SHA-256 `69f0ae680846edd95458d1e7aaabe36f8866f4f22a6d11488b126ed026b28963`. Manifest đi kèm lưu `row_id`, chỉ số nguồn, nhãn, SHA-256 mẫu, thời điểm `appeared`, `avclass` nếu có và hash của vector đặc trưng; SHA-256 manifest là `a2ca16402653e6cc51fdd7a4857d007faf86807b044d78654f180409c73565bb`.

Đối chiếu xác nhận 2.000 `row_id`, chỉ số nguồn và SHA-256 đều duy nhất; nhãn giữa dữ liệu và manifest khớp; hash vector đặc trưng khớp và không có hai vector trùng hoàn toàn. Trường `appeared` nằm trong tháng 11–12/2018; `avclass` có ở 498 mẫu. Nhãn dương của EMBER là malware nói chung, còn `avclass` chỉ là metadata họ yếu. Vì vậy, các kết quả dưới đây hỗ trợ kết luận về phân loại malware tĩnh trên mẫu EMBER đã định danh, không tự xác nhận phát hiện ransomware, họ chưa thấy, zero-day hoặc hiệu quả của PID.

Bảng 4.1: Phân hoạch trong mỗi outer fold

Vai trò	Benign	Malware	Tổng
Train/pool	900	300	1.200
Validation	300	100	400
Test	300	100	400
Tổng	1.500	500	2.000

4.1.2 Phân hoạch và kiểm soát rò rỉ

Nghiên cứu sử dụng 5 outer folds phân tầng. Trong mỗi fold, 400 mẫu được giữ làm test; 1.600 mẫu còn lại được chia thành 1.200 train/pool và 400 validation. Do đó, mỗi mẫu được kiểm thử đúng một lần ở cấp outer fold. Năm seed AL $11, 22, 33, 44, 55$ chia sẻ cùng tập khởi tạo giữa các phương pháp trong từng fold. Fidelity dùng năm seed mô hình $41, 42, 43, 44, 45$ trên cùng manifest phân hoạch. Các seed trong một fold được lấy trung bình trước khi tính chênh lệch giữa các phương pháp; đơn vị đối chiếu chính là outer fold, tránh coi nhiều seed trên cùng test là các tập độc lập.

Bảng 4.2: Vai trò dữ liệu và điều kiện kiểm soát

Tập	Cách sử dụng	Điều kiện kiểm soát
Train/pool	Huấn luyện tích lũy AL; huấn luyện mô hình Fidelity và tính baseline che.	Nhãn pool chỉ được mở sau khi mẫu đã được chọn.
Validation	Chọn threshold và xác định target ngân sách AL.	Không gộp vào ngân sách huấn luyện; không dùng test để đặt target.
Test	Đo ROC-AUC, AP, vùng FPR thấp, deletion và stability.	Không tham gia huấn luyện, xếp hạng ứng viên hoặc dừng.

Trong AL, mỗi phương pháp bắt đầu từ 200 nhãn và thực hiện 10 vòng, mỗi vòng truy vấn 100 mẫu, đến khi dùng đủ 1.200 mẫu train/pool. Điểm đích được đặt bằng 95% phần AUC vượt mức ngẫu nhiên của mô hình full-pool trên validation:

$$AUC_{target} = 0{,}5 + 0{,}95\left(AUC_{full,val} - 0{,}5\right). \tag{4.1}$$

Quy tắc này được xác định từ validation riêng cho từng fold; test không tham gia xác định đích. Điểm cuối 1.200 nhãn giống nhau giữa các phương pháp vì chúng đã dùng cùng toàn bộ pool. Do đó, hiệu quả AL được đọc từ diện tích dưới đường học (AULC)

và số nhãn đạt đích, không chỉ từ điểm cuối.

4.1.3 Môi trường và cấu hình mô hình

Runner sử dụng Python 3.12.14, LightGBM 4.7.0, NumPy 2.5.3, pandas 3.0.6 và scikit-learn 1.9.1. Mô hình chạy trên CPU với hai luồng, bật `deterministic` và `force_col_wise`. TreeSHAP được tính bằng `pred_contrib=True` ở thang raw score; cột bias được loại khỏi tín hiệu chọn mẫu và được cộng lại khi kiểm tra additivity.

AL dùng 60 cây, learning rate 0,05, tối đa 15 lá, độ sâu tối đa 4 và tối thiểu 10 mẫu mỗi lá. Fidelity dùng 100 cây, learning rate 0,1, tối đa 15 lá, độ sâu tối đa 4, tối thiểu 20 mẫu mỗi lá, feature fraction và bagging fraction đều bằng 0,8. Các cấu hình giữa phương pháp trong cùng thực nghiệm được giữ cố định.

4.1.4 Chỉ số và phạm vi đo chi phí

Ngoài ROC-AUC và average precision (AP) [7, 21], AL báo normalized AULC theo ngân sách, standardized partial AUC tại $FPR \leq 5\%$, TPR tại threshold chọn trên validation với giới hạn FPR 1% và 5%, cùng số nhãn đạt target. Các kết quả điểm vận hành luôn báo TPR và FPR cùng nhau. Mỗi test fold có 300 mẫu benign, nên một false positive làm FPR thay đổi khoảng 0,333 điểm phần trăm; đây vẫn là giới hạn khi suy rộng tới mức FPR vận hành rất thấp.

Thời gian truy vấn AL gồm dự đoán trên pool, TreeSHAP nếu có, kiểm tra additivity và chuẩn hóa tín hiệu. Tổng *model + query* gồm thời gian huấn luyện checkpoint và tính điểm truy vấn; không gồm thời gian chuyên gia gán nhãn, sandbox hoặc độ trễ hệ thống đầu cuối. Vì vậy, số nhãn là đại diện trực tiếp hơn cho chi phí oracle trong thực nghiệm này, còn thời gian chỉ phản ánh overhead tính toán của runner.

4.2 Phân tích và phạm vi đánh giá cơ chế dung hợp đa tầng

4.2.1 Bằng chứng hiện có

Đợt thực nghiệm được báo cáo trong bản luận văn này sử dụng tập con 2.000 vector đặc trưng tĩnh để đánh giá Học tích cực và chất lượng giải thích. Tập dữ liệu này chưa kèm các quan sát động thực có thể ghép theo định danh của cùng tệp và phiên thực thi. Vì vậy, đợt đánh giá hiện tại chưa cung cấp so sánh thực nghiệm có kiểm soát giữa Static-only, Dynamic-only, dung hợp trọng số cố định và PID.

Phần này trình bày kết quả phân tích cơ chế và thiết kế đối chứng để xác định đóng góp riêng của PID. Các kết quả định lượng Học tích cực và Fidelity ở các mục sau được giới hạn trong những thành phần đã thực hiện phép đo; chưa suy rộng sang nhánh động hoặc hiệu quả dung hợp toàn hệ thống.

4.2.2 Kết quả phân tích cơ chế

Theo Công thức (3.7), điểm dung hợp nằm giữa hai điểm đầu vào, và chi phí riêng bước cập nhật là $O(1)$. Hai tính chất này xác nhận một phần tính hợp lệ của cách kết hợp, nhưng chưa xác nhận lợi ích phân loại. Phân tích thành phần P tại Công thức (3.8) cho thấy cơ chế có thể thiên về điểm lớp dương lớn hơn; vì vậy giả thuyết giảm báo động nhầm phải được kiểm tra thay vì suy ra từ cấu trúc PID.

Lý do cần so sánh với dung hợp trọng số cố định là cả hai cách đều sử dụng thông tin từ hai nguồn. Nếu chỉ so PID với phân tích tĩnh, phần cải thiện có thể đến từ việc bổ sung tín hiệu động. Tương tự, nếu PID được nhận nhiều thời gian quan sát hơn một đối chứng, chênh lệch chất lượng có thể do lượng thông tin đầu vào. Muốn đánh giá riêng công thức cập nhật trọng số, cần giữ các yếu tố này giống nhau.

4.2.3 Đối chứng cần thiết để xác nhận đóng góp PID

Bảng 4.3 xác định các phép so sánh cần thực hiện khi có cặp tín hiệu thực. Đây là thiết kế đối chứng, chưa phải bảng kết quả đo. Trọng số cố định, hệ số PID, ngưỡng quyết định và ngưỡng cổng phải được chọn trên tập xác thực trước khi đánh giá tập kiểm thử đã khóa.

Bảng 4.3: Các đối chứng xác định đóng góp của nhánh động và công thức dung hợp

Cấu hình	Đầu vào	Câu hỏi đánh giá
Static-only	Điểm tĩnh của từng mẫu.	Nhánh tĩnh đạt chất lượng nào trên tập chung?
Dynamic-only	Điểm động thực của cùng mẫu.	Quan sát động cung cấp giá trị gì và tốn bao nhiêu thời gian?
Trung bình 50/50	Cặp điểm tĩnh–động.	Chỉ kết hợp hai nguồn đã cải thiện đến đâu?
Trọng số cố định	Cùng cặp điểm; trọng số chọn trên validation.	Một đối chứng đơn giản được tinh chỉnh có đủ tốt không?
P, PI và PID	Cùng cặp điểm và thứ tự quan sát.	Thành phần tỷ lệ, lịch sử và sai phân đóng góp như thế nào?

Trong nhóm các cấu hình dung hợp, phải giữ chung cổng kích hoạt, cửa sổ quan sát động, thứ tự mẫu và quy tắc reset. Cần báo cáo AUC, PR-AUC, FP/FN và FPR cùng TPR tại ngưỡng được chọn trên validation. So sánh FPR có ý nghĩa khi kiểm soát mức phát hiện; một mức FPR thấp hơn nhưng bỏ sót nhiều hơn không tự xác lập ưu thế vận hành. Dự đoán từng mẫu cho phép phân tích chênh lệch ghép cặp; các lần lặp với điều kiện chung giúp đánh giá độ nhạy thay vì dựa vào một lần chạy.

Độ trễ dung hợp cần đo từ thời điểm cả hai điểm đã sẵn sàng đến khi tính xong kết quả; độ trễ đầu cuối còn bao gồm trích đặc trưng, chờ tài nguyên và quan sát động. Phép đo riêng bước cập nhật trọng số không chứng minh hệ thống đưa ra quyết định trong cùng thời gian đó kể từ khi nhận tệp. Cần ghi rõ mốc đo và báo cáo phân vị của từng loại độ trễ, thay vì so sánh các thời gian có phạm vi khác nhau.

4.2.4 Phân tách đóng góp khi tích hợp Học tích cực

Sau khi có dữ liệu dung hợp phù hợp, một thiết kế 2×2 gồm {trọng số cố định, PID} $\times$ {chọn mẫu ngẫu nhiên, XAI-guided AL} sẽ phân tách đóng góp của cập nhật trọng số và chọn nhãn. Bốn cấu hình phải dùng cùng tập khởi tạo, pool, tập xác thực, tập kiểm thử, ngân sách nhãn và lịch tái huấn luyện. Nhánh động và chính sách quan sát được giữ chung. Đối chứng uncertainty-only được dùng bổ sung để xác định lợi ích của tín hiệu XAI ngoài bất định đầu ra.

Thiết kế này cho phép phân biệt lợi ích của việc có thêm nhãn với lợi ích của cách lựa chọn nhãn, đồng thời kiểm tra PID có còn tạo chênh lệch khi mô hình tĩnh được cập nhật. Muốn kết luận có tương tác giữa PID và XAI-AL, cần phân tích chênh lệch của cả bốn cấu hình trên cùng thang đo; việc cấu hình đầy đủ đứng đầu riêng lẻ chưa đủ chứng minh cộng hưởng. Trong phạm vi dữ liệu hiện tại, luận văn chưa kết luận mức cải thiện của toàn hệ thống hoặc mức tiết kiệm chi phí từ sự kết hợp này.

4.3 Đánh giá mô hình Học tích cực hướng dẫn bởi XAI

4.3.1 Biến thể và giao thức đối chứng

Thực nghiệm kiểm tra liệu tín hiệu giải thích có cải thiện lựa chọn mẫu so với Random và Uncertainty khi giữ nguyên dữ liệu, mô hình và ngân sách. Năm chiến lược gồm Random, Uncertainty, kết hợp độ bất định với Directional Entropy ($U + H$), kết hợp độ bất định với phương sai SHAP ($U + V$), và cấu hình đầy đủ $U + H + V$ (XAI đầy đủ). Cấu hình đầy đủ dùng trọng số $(0{,}3; 0{,}4; 0{,}3)$; khi loại một thành phần, các trọng số còn lại được chuẩn hóa về tổng 1.

Độ bất định là $U(x) = 1 - 2|p(x) - 0{,}5|$. Directional Entropy được tính từ tỷ lệ tổng độ lớn đóng góp SHAP dương và âm; $V(x)$ là phương sai các giá trị SHAP có dấu. Ba tín hiệu được chuẩn hóa min–max trên pool hiện tại trước khi kết hợp. TreeSHAP được tính lại từ mô hình hiện tại ở mỗi vòng; vì vậy tín hiệu truy vấn thay đổi khi tập có nhãn thay đổi. Hàm chấm điểm không truy cập nhãn của các mẫu chưa được chọn.

Mỗi outer fold có 5 seed ghép cặp, 200 nhãn khởi tạo và 10 vòng truy vấn, mỗi vòng 100 mẫu. Tổng cộng runner đã kiểm tra lại 1.375 checkpoint, 1.100.000 bản ghi dự đoán và 125.000 bản ghi truy vấn; 5/5 fold vượt toàn bộ kiểm tra nhất quán. Năm seed trong cùng fold được lấy trung bình trước khi tính hiệu ứng, nên số fold độc lập

dùng cho so sánh là 5.

4.3.2 Hiệu quả đường học và ngân sách nhãn

Bảng 4.4 trình bày normalized AULC từ 200 đến 1.200 nhãn, ngân sách trung bình đầu tiên đạt target validation và chi phí tính toán. AULC cao hơn nghĩa là mô hình đạt chất lượng tốt sớm hơn trong toàn bộ quá trình truy vấn. Ngân sách đạt target thấp hơn nghĩa là cần ít nhãn oracle hơn theo tiêu chí đã khóa trước.

Bảng 4.4: Kết quả Active Learning tổng hợp qua 5 outer folds

Chiến lược	ROC-AULC	AP-AULC	Nhãn đích	Query (s)	Model+query (s)
Random	0,928777	0,868350	584	0,0194	4,1947
Uncertainty	0,931272	0,881934	520	0,0191	4,1454
$U + H$	**0,933026**	**0,883336**	508	0,2459	4,4741
$U + V$	0,930377	0,880164	**488**	0,2298	4,3826
XAI đầy đủ	0,932202	0,881638	492	0,2358	4,3471

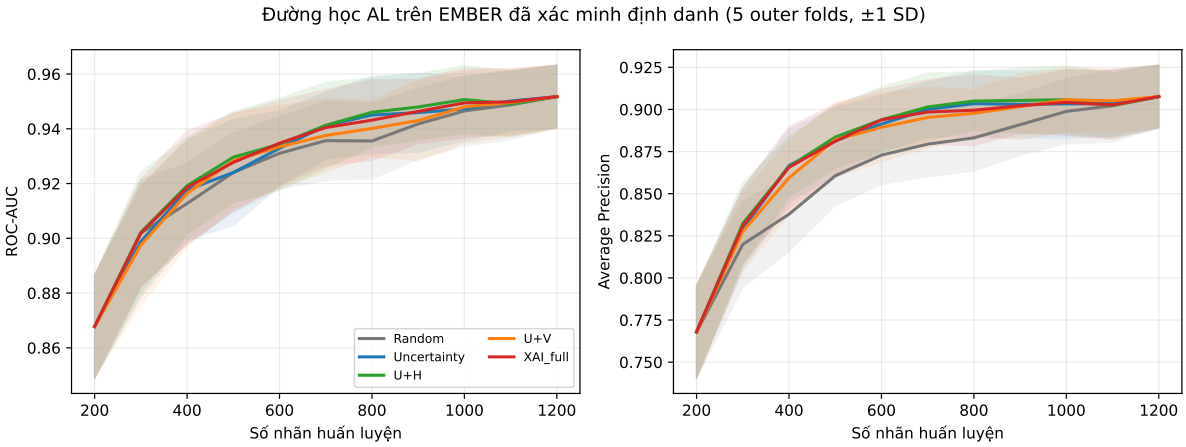
$U + H$ có ROC-AULC và AP-AULC cao nhất, còn $U + V$ đạt target với ít nhãn nhất. Cấu hình đầy đủ nằm giữa hai mục tiêu. Kết quả này cho thấy thêm mọi tín hiệu không mặc nhiên tạo cấu hình tốt nhất; các thành phần tạo ra đánh đổi giữa chất lượng trung bình của đường học và tốc độ đạt đích.

So với Random, $U + H$ tăng ROC-AULC $0{,}004249$ và AP-AULC $0{,}014985$, cùng chiều ở 5/5 fold; số nhãn giảm trung bình 76, tương đương 13,0%. So với Uncertainty, mức tăng là $0{,}001754$ ROC-AULC và $0{,}001401$ AP-AULC, cùng chiều ở 4/5 fold; số nhãn chỉ giảm trung bình 12 và tốt hơn ở 2/5 fold. XAI đầy đủ so với Random tăng ROC-AULC $0{,}003425$, AP-AULC $0{,}013287$, cùng chiều ở 5/5 fold và giảm trung bình 92 nhãn. So với Uncertainty, ROC-AULC chỉ tăng $0{,}000931$, AP-AULC giảm $0{,}000297$, nên chưa có bằng chứng cấu hình đầy đủ vượt đối chứng mạnh một cách nhất quán.

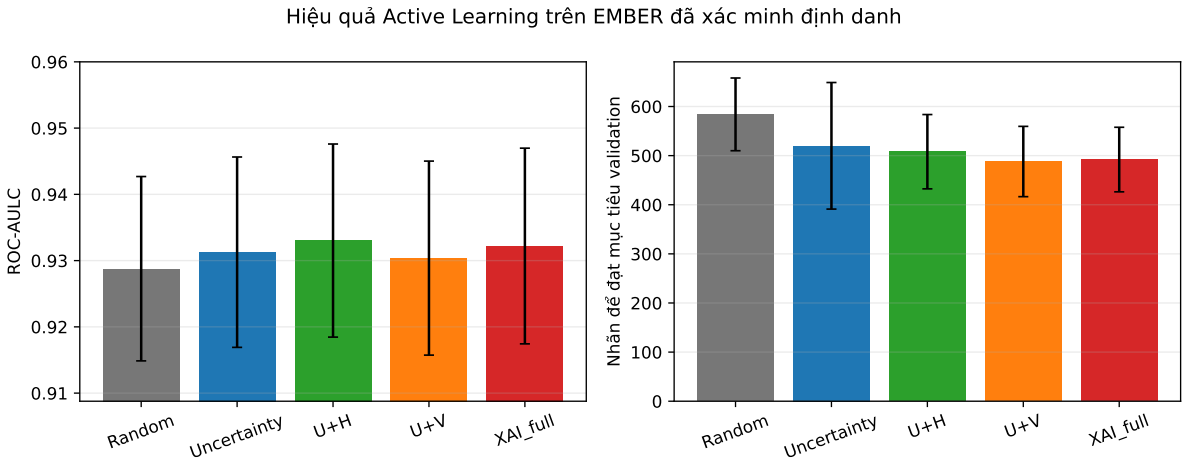
4.3.3 Hiệu quả trong vùng FPR thấp

Bảng 4.5 báo normalized AULC của các metric vùng FPR thấp dọc theo ngân sách. Standardized pAUC tập trung vào $FPR \leq 5\%$. Hai cột TPR sử dụng threshold được chọn trên validation với giới hạn FPR tương ứng; cách này tránh điều chỉnh threshold trực tiếp trên test.

So với Random, $U + H$ tăng TPR-AULC $0{,}05616$ tại cap 1% và $0{,}03864$ tại cap 5%, cùng chiều ở 5/5 fold. So với Uncertainty, chênh lệch tương ứng là $-0{,}00140$ và $+0{,}00136$. XAI đầy đủ cũng vượt Random trên cả 5 fold, nhưng gần như hòa Uncertainty. Do đó, bằng chứng hiện tại cho thấy XAI-guided AL cải thiện rõ so với chọn ngẫu nhiên ở vùng



Hình 4.1: Đường học ROC-AUC, AP và các chỉ số vùng FPR thấp từ 200 đến 1.200 nhãn. Dải biến thiên được tính sau khi gộp seed trong từng outer fold.



Hình 4.2: So sánh AULC, ngân sách đạt target và overhead của năm chiến lược. Điểm cuối 1.200 nhãn giống nhau do mọi phương pháp đã dùng toàn bộ pool.

Bảng 4.5: AULC của các chỉ số vùng FPR thấp

Chiến lược	**pAUC** $FPR \leq 5\%$	**TPR@cap 1%**	**TPR@cap 5%**
Random	0,804096	0,580620	0,731980
Uncertainty	**0,826300**	**0,638180**	0,769260
$U + H$	0,824774	0,636780	0,770620
$U + V$	0,825194	0,626260	0,768140
XAI đầy đủ	0,823525	0,631860	**0,771460**

FPR thấp; chưa chứng minh XAI giảm cảnh báo nhầm tốt hơn Uncertainty một cách ổn định.

4.3.4 Overhead và ý nghĩa thực tiễn

Query của $U + H$ tăng khoảng 0,227 giây cho 10 vòng so với Uncertainty; tổng thời gian model+query tăng khoảng 7,93%. Với XAI đầy đủ, overhead tổng tương ứng khoảng 4,86%. Ở quy mô 2.000 mẫu, phần tăng này nhỏ hơn nhiều so với chi phí gán nhãn chuyên gia, nhưng thực nghiệm chưa đo thời gian analyst. Vì vậy, đóng góp được kết luận ở hai mức: số truy vấn oracle cần thiết và overhead tính toán của pipeline; không quy đổi trực tiếp số nhãn thành giờ công.

Kết quả cũng giải thích vì sao chỉ nhìn AUC cuối cùng là không phù hợp. Khi đạt 1.200 nhãn, mọi phương pháp hội tụ về cùng mô hình full-pool với ROC-AUC trung bình 0,951753 và AP 0,907628. Khác biệt nằm ở tốc độ tiến tới chất lượng đó, số nhãn cần dùng và hiệu quả ở vùng FPR thấp. Đây là ý nghĩa vận hành chính của đóng góp AL, thay vì một mức tăng vài phần nghìn tại một checkpoint đơn lẻ.

4.4 Đánh giá Fidelity và độ ổn định của TreeSHAP

4.4.1 Sự phù hợp của phép đo với dữ liệu mã độc

Faithfulness, Consistency và Contrastive không phải chuẩn đặc thù duy nhất cho mã độc. Luận văn sử dụng chúng như các phép đo tương đối đối với lời giải thích của mô hình trên vector PE. Sự chuyển giao này phù hợp ở mức mô hình vì cả dữ liệu ảnh và vector EMBER đều có thể biểu diễn đầu vào thành các chiều số và đo thay đổi đầu ra khi perturb các chiều quan trọng. Tuy nhiên, khác với pixel ảnh, các trường và nhóm đặc trưng PE có phụ thuộc cấu trúc, băm và ràng buộc định dạng. Thay một tọa độ bằng mean hoặc median không bảo đảm tạo ra một tệp PE thực thi hợp lệ. Do đó, kết quả chỉ đánh giá sự phụ thuộc của mô hình trong không gian đặc trưng EMBER; không được diễn giải thành can thiệp nhân quả lên hành vi mã độc.

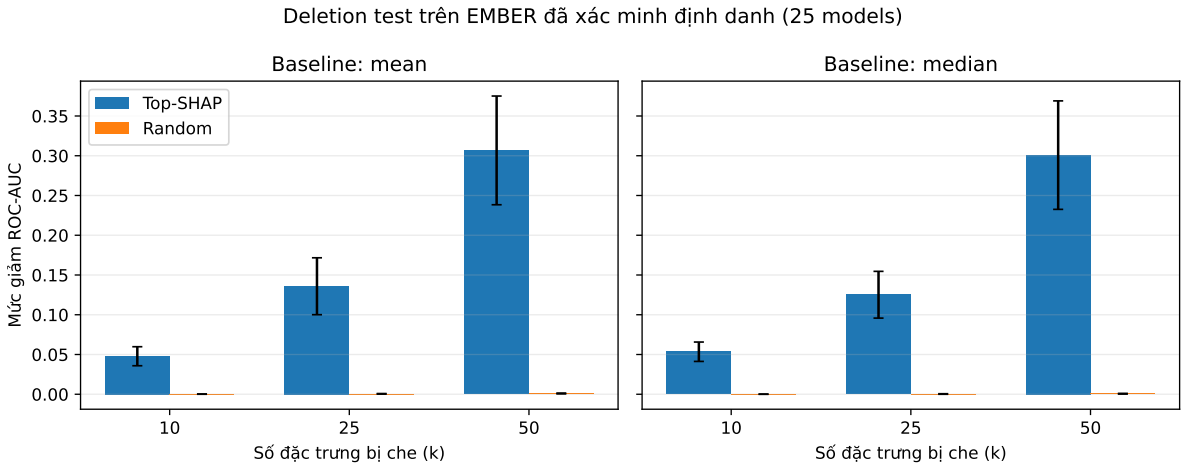
Để giảm phụ thuộc vào một phép che duy nhất, thực nghiệm dùng hai baseline lấy từ train: mean và median. Với mỗi baseline, các $k = 10, 25, 50$ chiều có $|\phi|$ lớn nhất được che và so với 20 random masks cùng k. Giao thức được lặp trên 5 outer folds và 5 seed mô hình, tạo 25 mô hình và 50 tổ hợp mô hình–baseline. Toàn bộ 50/50 lượt, 3.150 nhóm mask và 1.260.000 bản ghi dự đoán đã vượt kiểm tra replay.

4.4.2 Faithfulness bằng deletion có đối chứng

Mô hình chưa che có ROC-AUC trung bình $0{,}956720 \pm 0{,}012541$ và AP $0{,}922931 \pm 0{,}014881$ qua 25 mô hình. Bảng 4.6 báo độ giảm AUC sau che. Với mọi k và cả hai baseline, top-SHAP làm AUC giảm lớn hơn random mask cùng ngân sách.

Bảng 4.6: Giảm AUC khi che top-SHAP và che ngẫu nhiên; trung bình qua 25 mô hình

Baseline	k	**Top-SHAP**	**Random**	**Chênh lệch**
Mean	10	0,047817	0,000200	0,047617
Mean	25	0,135853	0,000530	0,135323
Mean	50	0,306729	0,000979	0,305750
Median	10	0,053483	0,000094	0,053388
Median	25	0,125180	0,000326	0,124854
Median	50	0,300777	0,000658	0,300119



Hình 4.3: Deletion effect của top-SHAP so với random control dưới mean và median baseline.

Ở $k = 25$, chênh lệch top-SHAP trừ random đạt 0,135323 với mean và 0,124854 với median. Sự lặp lại theo fold, seed, k và baseline cho bằng chứng mạnh hơn một mô hình đơn lẻ: thứ hạng TreeSHAP xác định được các chiều mà dự đoán của mô hình phụ thuộc dưới giao thức deletion đã khóa. Tuy nhiên, mức giảm không phải xác suất nhân quả và có thể chứa ảnh hưởng của vector ngoài phân phối.

Chỉ số Faithfulness thô theo công thức thay đổi xác suất tương đối, $|p-p_{mask}|/(p+\epsilon)$, có trung bình 24,214574 tại $k = 25$ với mean và 30,482143 với median. Giá trị lớn hơn 1 là hợp lệ theo công thức nhưng khiến chỉ số khó ghép trực tiếp với EC hoặc CF; vì vậy luận văn ưu tiên AUC drop có random control làm kết quả faithfulness chính.

4.4.3 Consistency và Contrastive

EC đo tương quan giữa cấu trúc tương đồng của mẫu trong không gian đặc trưng đã chuẩn hóa và không gian SHAP. Qua 25 mô hình, EC trung bình là $0{,}426816 \pm 0{,}036645$. CF đo độ tách tâm hai lớp trong không gian SHAP sau chuẩn hóa theo độ lớn giải thích; CF trung bình là $0{,}468017 \pm 0{,}047026$. Hai đại lượng hỗ trợ so sánh giữa cấu hình theo cùng định nghĩa, nhưng chưa có ngưỡng phổ quát để gắn nhãn một lời giải thích là "đạt" hay "không đạt".

Độ ổn định thứ hạng được đánh giá trực tiếp bằng Spearman của global importance và Jaccard của tập top-k. Bảng 4.7 phân biệt thay đổi seed trong cùng fold với thay đổi cả phân hoạch dữ liệu.

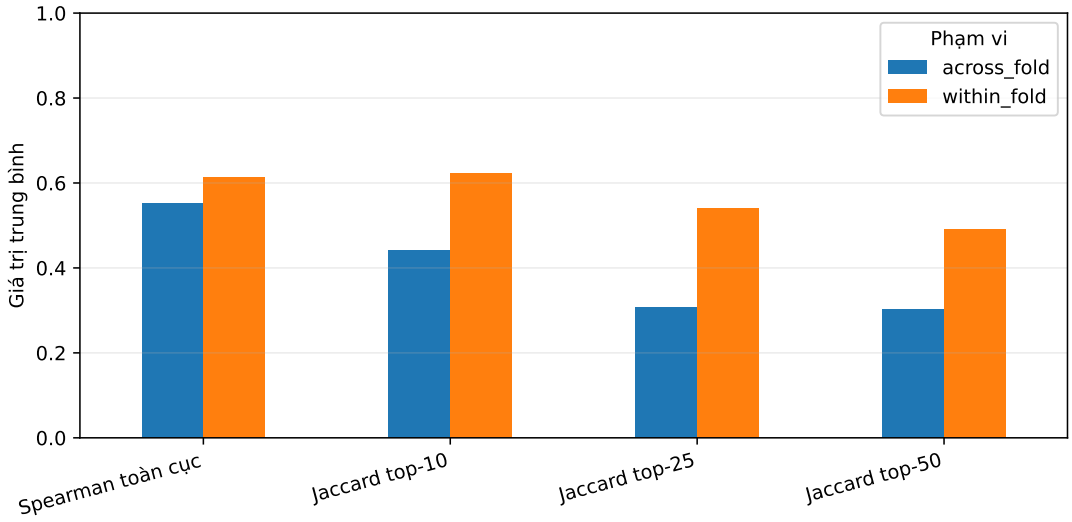
Bảng 4.7: Độ ổn định TreeSHAP giữa các mô hình

So sánh	Spearman	Jaccard@10	Jaccard@25	Jaccard@50
Cùng fold, khác seed	0,614440	0,622065	0,539842	0,490138
Khác fold	0,551161	0,441612	0,307294	0,302017

Giải thích ổn định hơn khi chỉ đổi seed trong cùng fold và giảm rõ khi thay đổi phân hoạch. Đây là một kết quả cần báo cáo, không phải lỗi cần che giấu: nó cho thấy danh sách top feature có độ nhạy dữ liệu và chuyên gia không nên coi một thứ hạng duy nhất là bất biến.

4.4.4 Lý do chưa tổng hợp OFS

Faithfulness thô không bị chặn trên $[0, 1]$; EC có thể âm; CF phụ thuộc chuẩn hóa và có thể vượt 1. Nếu cộng trực tiếp, thành phần có biên độ lớn sẽ chi phối OFS mà không phản ánh ưu tiên thực tế. Một OFS có thể bảo vệ được cần khóa trước: (i) quy tắc đưa từng thành phần về thang chung dựa trên baseline; (ii) chiều tốt/xấu của mỗi metric; (iii) trọng số theo mục tiêu sử dụng; và (iv) phân tích độ nhạy trọng số trên dữ liệu ngoài tập



Hình 4.4: Độ ổn định thứ hạng và tập đặc trưng SHAP khi đổi seed hoặc đổi outer fold.

hiệu chỉnh. Vì các điều kiện này chưa được kiểm định độc lập, luận văn báo ba nhóm bằng chứng riêng và để OFS ở trạng thái chưa tổng hợp. Quyết định này tránh tạo một con số chính xác giả tạo từ các đại lượng không đồng nhất.

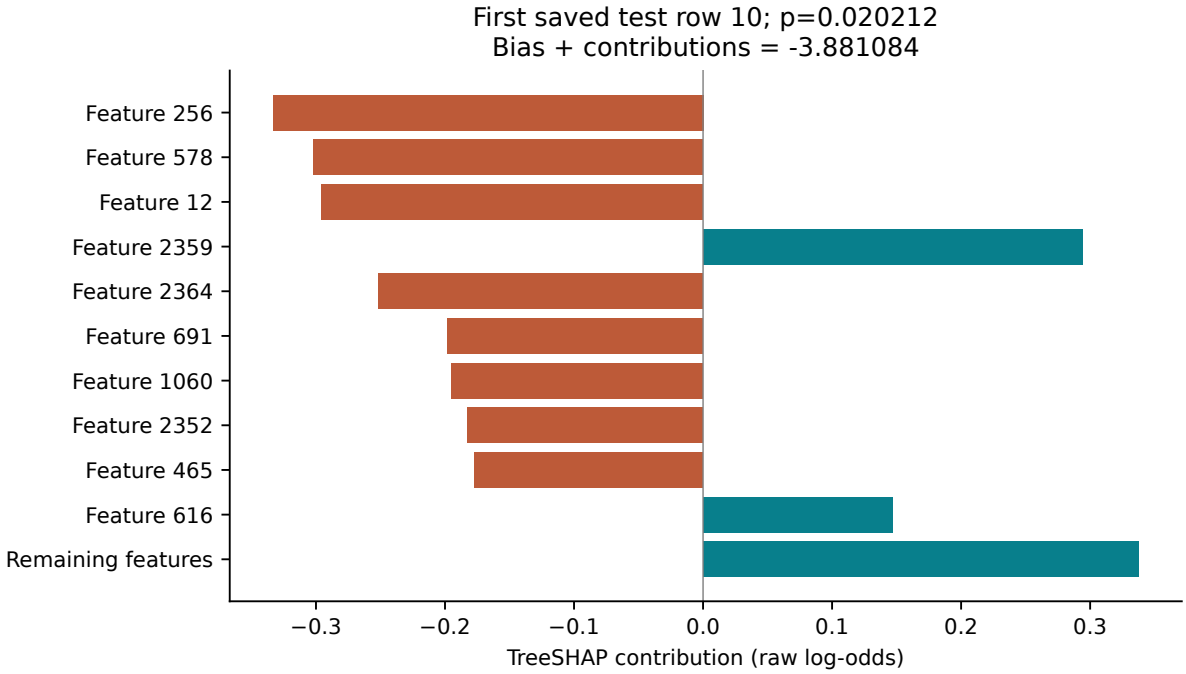
4.5 Minh họa giải thích trên một mẫu kiểm thử

Để liên hệ các đại lượng tổng hợp với một dự đoán cụ thể, mục này dùng mẫu đầu tiên trong danh sách test đã lưu của fold 0, seed 41 và mean baseline. Quy tắc chọn theo thứ tự đã lưu, không chọn mẫu thuận lợi nhất. Mẫu có `row_id=10`, chỉ số nguồn EMBER 6330, SHA-256 `09075e5313d9638e622ee0aa98167135a19403193bc70627e11d687ac447fd70`, nhãn benign và xác suất malware 0,020212.

Thanh dương làm tăng raw score của lớp malware, thanh âm làm giảm raw score so với giá trị nền. Tổng đóng góp và bias khớp raw score với sai số additivity không quá $5{,}33 \times 10^{-15}$. Phép sigmoid của raw score cho xác suất 0,020212. Tính cộng xác nhận cách TreeSHAP phân rã đầu ra mô hình ở thang log-odds; nó không biến từng thanh thành một xác suất độc lập.

Trong cùng model, che 25 chiều top-SHAP bằng mean làm AUC giảm từ 0,967300 xuống 0,839233, trong khi random mask cùng số chiều cho AUC trung bình 0,967388 qua 20 lần lặp. Ví dụ cục bộ vì thế được đặt trong bằng chứng tổng hợp của toàn bộ test, không dùng riêng để kết luận chất lượng giải thích.

Các chiều vẫn được ghi bằng chỉ số vì nhiều nhóm đặc trưng EMBER dùng feature hashing; một tọa độ không luôn ánh xạ duy nhất về một API. Biểu đồ này giải thích mô hình tĩnh của một lần huấn luyện, không xác nhận mẫu thuộc họ ransomware và không giải thích quyết định dung hợp PID.



Hình 4.5: Đóng góp TreeSHAP của mẫu đầu tiên trong test fold 0. Mười chiều có trị tuyệt đối lớn nhất được hiển thị riêng; các chiều còn lại được gộp.

4.6 Cấu hình đã chạy và dấu vết tái lập

4.6.1 Cấu hình cố định

Các giá trị trong Bảng 4.8 là cấu hình đã chạy, không phải kết quả của grid search trên test. Mỗi phương pháp trong cùng thực nghiệm dùng cùng năng lực mô hình.

Bảng 4.8: Cấu hình hai thực nghiệm xác nhận

Tham số	**AL**	**Fidelity**
Outer folds	5	5
Seed mỗi fold	11, 22, 33, 44, 55	41, 42, 43, 44, 45
Số cây	60	100
Learning rate	0,05	0,1
Số lá tối đa	15	15
Độ sâu tối đa	4	4
Số mẫu tối thiểu mỗi lá	10	20
Số luồng CPU	2	2
Ngân sách/mẫu train	200–1.200	1.200
Thiết lập bổ sung	10 vòng $\times$ 100 nhãn	mean/median; $k = 10, 25, 50$

4.6.2 Đầu ra và kiểm chứng

Thực nghiệm AL tạo 1.375 checkpoint, gồm 5 folds, 5 phương pháp, 5 seed và 11 mức ngân sách. Hệ thống lưu 1.100.000 dự đoán validation/test và 125.000 bản ghi truy vấn. Fidelity tạo 25 mô hình, mỗi mô hình được đánh giá với hai baseline; tổng cộng 50 lượt chạy, 3.150 nhóm mask và 1.260.000 bản ghi dự đoán. Số bản ghi là tổng qua các thực nghiệm lặp, không phải số mẫu khác nhau cần chuyên gia gán nhãn trong thực tế.

Bảng 4.9: Artifacts dùng để truy vết kết quả

Tệp hoặc nhóm tệp	Nội dung kiểm tra
`config.json`, manifests	Tham số, seed, phiên bản, hash dữ liệu, chỉ số train/validation/test và provenance từng dòng.
`metrics_all_folds.csv`	Metric từng checkpoint và thời gian huấn luyện/truy vấn AL.
`fold_level_effects.csv`	Chênh lệch ghép cặp theo outer fold, số fold thắng và độ lệch chuẩn.
`budget_to_target_all_folds.csv`	Ngân sách đầu tiên đạt target xác định từ validation.
`model_metrics.csv`, `mask_metrics_all_models.csv`	AUC/AP, EC, CF và dự đoán trước/sau che trên 25 mô hình.
`verification.json`, `SHA256SUMS`	Kết quả replay, kiểm tra số dòng và hash 41 artifacts của gói bằng chứng.

Hậu kiểm AL xác nhận các tập không giao nhau, mỗi mẫu chỉ được truy vấn một lần trong một quỹ đạo, tập khởi tạo chung giữa các phương pháp và AUC/AP tái tính từ dự đoán khớp bảng metric. Fidelity kiểm tra additivity của TreeSHAP, số mask, số dự đoán và metric tái tính. Gói kết quả được tạo từ commit `fed4322f58f5bb55ec47833e857370d076592a32` khi working tree sạch, sau đó lưu tại `results/confirmatory_20261019_ember_identity`. Lệnh `sha256sum -c SHA256SUMS` phải được chạy từ gốc thư mục gói.

Các kiểm tra này xác nhận tính nhất quán của phép tính và quan hệ giữa dữ liệu–manifest–đầu ra. Chúng không thay thế dữ liệu động, kiểm thử theo họ/thời gian hoặc đánh giá ở một tổ chức vận hành độc lập.

4.7 Diễn giải kết quả và các mối đe dọa tới tính hợp lệ

4.7.1 Tính hợp lệ nội tại

Các đối chứng AL dùng cùng outer folds, tập khởi tạo, ngân sách và cấu hình mô hình. Nhãn chưa truy vấn không tham gia điểm chọn mẫu; validation đặt target và threshold, còn test chỉ đánh giá. Việc lấy trung bình seed trong fold trước khi tính hiệu ứng giữ outer fold làm đơn vị so sánh. Tuy vậy, năm fold cùng được tạo từ một tập 2.000 mẫu; chúng mô tả biến thiên phân hoạch nội bộ, không tương đương năm bộ dữ liệu độc lập.

Fidelity giữ cùng số chiều giữa top-SHAP và random control, lặp qua seed, fold, k và mean/median baseline. Random control không bảo đảm độ lớn perturbation giống top-SHAP; mean/median replacement có thể tạo tổ hợp ngoài phân phối. Do đó, deletion hỗ trợ nhận định về sự phụ thuộc của mô hình, không chứng minh nhân quả hoặc tính hợp lệ của tệp PE sau biến đổi.

4.7.2 Tính hợp lệ ngoại tại

Manifest xác nhận định danh và nguồn EMBER của các dòng, khắc phục hạn chế provenance của lần đo ban đầu. Tuy nhiên, nhãn 1 vẫn là malware nói chung; `avclass` có ở 498 mẫu và không phải ground truth ransomware. Random stratified folds không thiết lập khả năng khái quát theo họ, thời gian, zero-day hoặc cross-dataset. Tỷ lệ malware 25% cũng cao hơn nhiều môi trường doanh nghiệp; precision và khối lượng cảnh báo sẽ thay đổi khi base rate thay đổi.

Tập dữ liệu không chứa executable hoặc behavior trace. Vì vậy, kết quả trong chương không xác nhận PID giảm FPR, cổng bất định tối ưu chi phí sandbox hay toàn hệ thống đạt độ trễ thời gian thực. Các tuyên bố đó cần dữ liệu tĩnh–động ghép theo SHA-256 và ablation Static-only, Dynamic-only, fixed-weight, P, PI, PID trên cùng split.

4.7.3 Tính hợp lệ của các metric

ROC-AULC, AP-AULC và ngân sách đạt target đo hiệu quả AL qua toàn bộ quá trình, phù hợp hơn AUC điểm cuối khi tất cả phương pháp dùng hết pool. Kết quả XAI vượt Random ổn định, nhưng phần tăng so với Uncertainty nhỏ và không đồng nhất trên mọi metric. Do đó, luận văn không mô tả XAI đầy đủ là phương pháp luôn tốt nhất.

Đối với low-FPR, threshold được chọn từ validation nhưng FPR quan sát trên test có thể vượt cap do sai khác mẫu. Mỗi test fold chỉ có 300 benign, nên độ phân giải FPR là khoảng 0,333 điểm phần trăm. Các kết quả vùng FPR thấp là bằng chứng so sánh trong tập nghiên cứu, chưa phải cam kết SLA vận hành.

Faithfulness thô, EC và CF có miền giá trị và ý nghĩa khác nhau. EC dùng các cặp chia sẻ mẫu; CF phản ánh phân tách lớp; FF thô nhạy khi xác suất gốc nhỏ. Không sử dụng số cặp EC như các quan sát độc lập và không tổng hợp OFS khi chưa có chuẩn hóa

cùng trọng số đã kiểm định.

4.7.4 Ý nghĩa đối với ba đóng góp

Đóng góp XAI-guided AL được hỗ trợ bằng 5 outer folds, 5 seed, hai baseline mạnh và ba cấu hình XAI. Bằng chứng chính là AULC, nhãn đạt target, hiệu quả vùng FPR thấp và overhead. Đóng góp đánh giá giải thích được hỗ trợ bằng deletion có random control dưới hai baseline cùng kiểm tra ổn định giữa mô hình. Đóng góp PID hiện ở mức luật dung hợp, phân tích toán học và đặc tả giao thức; chưa có dữ liệu động ghép cặp để gắn cho nó một mức cải thiện định lượng.

Việc giữ riêng ba mức bằng chứng là cần thiết: kết quả của AL không chứng minh PID, còn Fidelity không chứng minh phát hiện ransomware. Cách diễn giải này cho phép bảo vệ đúng phần đã đo và chỉ rõ điều kiện để mở rộng kết luận.

Chương 5
KẾT LUẬN VÀ HƯỚNG PHÁT TRIỂN

5.1 Kết quả đạt được của luận văn

Luận văn đề xuất một kiến trúc kết hợp phát hiện tĩnh, giải thích, cổng bất định, giám sát động, dung hợp PID và cập nhật mô hình bằng Học tích cực. Ba đóng góp được đánh giá ở các mức bằng chứng khác nhau: XAI-guided Active Learning và Fidelity có thực nghiệm xác nhận trên dữ liệu EMBER tĩnh đã định danh; PID có đặc tả phương pháp và giao thức đối chứng nhưng chưa có behavior trace ghép cặp để xác nhận hiệu quả.

Đối với Active Learning, nghiên cứu thực hiện 5 outer folds, 5 seed mỗi fold, 5 chiến lược và 11 mức ngân sách từ 200 đến 1.200 nhãn. $U+H$ đạt ROC-AULC 0,933026 và AP-AULC 0,883336, tăng 0,004249 và 0,014985 so với Random, cùng chiều ở 5/5 fold. Cấu hình này giảm trung bình 76 nhãn để đạt target. So với Uncertainty, mức tăng nhỏ hơn, lần lượt là 0,001754 và 0,001401, còn ngân sách biến động theo fold. XAI đầy đủ giảm trung bình 92 nhãn so với Random nhưng không tốt nhất trên mọi metric. Ở vùng FPR thấp, $U + H$ vượt Random rõ ràng nhưng gần như hòa Uncertainty. Vì vậy, đóng góp chính là cải thiện đường học và hiệu quả nhãn so với chọn ngẫu nhiên, cùng một lợi ích bổ sung nhỏ so với baseline mạnh.

Đối với Fidelity, 25 mô hình được đánh giá dưới mean và median baseline, ba mức k và 20 random masks. Tại $k = 25$, top-SHAP làm AUC giảm 0,135853 với mean và 0,125180 với median; random control chỉ giảm 0,000530 và 0,000326. Thứ hạng global importance có Spearman 0,6144 khi đổi seed trong cùng fold và 0,5512 khi đổi fold. Kết quả hỗ trợ faithfulness tương đối của TreeSHAP trong không gian đặc trưng EMBER, đồng thời cho thấy danh sách đặc trưng quan trọng nhạy với phân hoạch dữ liệu. EC trung bình đạt 0,426816 và CF đạt 0,468017 qua 25 mô hình. OFS không được tổng hợp vì các thành phần chưa có chung thang đo và trọng số đã kiểm định.

Gói bằng chứng lưu manifest, hash dữ liệu, cấu hình, metric theo fold, dự đoán, replay verification và SHA-256 của 41 artifacts. Toàn bộ 1.375 checkpoint AL và 50 lượt Fidelity vượt kiểm tra nhất quán. Việc truy vết này làm rõ số liệu nào đã đo, số liệu nào chưa có và ngăn kết luận của một thành phần bị gán cho toàn hệ thống.

5.2 Hạn chế của luận văn

Thứ nhất, EMBER cung cấp nhãn benign/malware, không phải ground truth ransomware. Metadata `avclass` chỉ có ở 498 mẫu và là nhãn họ yếu. Random outer folds không chứng

minh khả năng khái quát theo họ, thời gian, zero-day hoặc cross-dataset. Tỷ lệ malware 25% cũng không đại diện trực tiếp cho base rate của một tổ chức.

Thứ hai, XAI-guided AL vượt Random ổn định nhưng chỉ hơn Uncertainty một mức nhỏ và không đồng nhất trên mọi metric. Số nhãn oracle chưa được quy đổi thành thời gian chuyên gia. Overhead đã đo là thời gian huấn luyện và tính điểm trên pool, không phải latency endpoint hoặc throughput SOC.

Thứ ba, mean/median masking có thể tạo vector ngoài phân phối và không bảo đảm tương ứng một tệp PE hợp lệ. Deletion, EC, CF và stability đánh giá hành vi mô hình theo các quy ước đã công bố; chúng không chứng minh quan hệ nhân quả của hành vi mã độc. OFS cần đặc tả chuẩn hóa và trọng số độc lập trước khi sử dụng.

Thứ tư, dữ liệu hiện tại không chứa executable hoặc báo cáo động ghép theo SHA-256. Do đó, chưa thể phân biệt đóng góp của việc bổ sung tín hiệu động với đóng góp của luật PID, chưa đo Static-only, Dynamic-only, fixed-weight, P, PI và PID trên cùng mẫu, và chưa chứng minh PID giảm FPR hoặc chi phí vận hành.

5.3 Hướng phát triển tương lai

Ưu tiên đầu tiên là xây dựng tập tĩnh–động ghép cặp theo SHA-256 với nhãn, timestamp và provenance rõ ràng. Trên tập này, cần khóa split và đối chiếu Static-only, Dynamic-only, fixed fusion, P, PI và PID bằng ROC-AUC, AP, FPR tại TPR mục tiêu, calibration, số mẫu qua sandbox và độ trễ đầu cuối. Kiểm tra thứ tự mẫu, reset trạng thái, anti-windup và độ nhạy tham số là bắt buộc đối với một bộ điều khiển rời rạc có trạng thái.

Ưu tiên thứ hai là mở rộng đánh giá theo thời gian và theo họ. Family-held-out hoặc temporal split mới hỗ trợ kết luận về biến thể chưa thấy; một tập ngoài EMBER giúp kiểm tra khả năng khái quát cross-dataset. Cần loại trùng và near-duplicate theo hash hoặc quan hệ nguồn trước khi chia tập.

Ưu tiên thứ ba là đánh giá chi phí gán nhãn thực tế. Ngoài số truy vấn, cần ghi thời gian analyst, tỷ lệ nhãn bất đồng, số mẫu cần phân tích động và lợi ích theo từng mức ngân sách. Có thể so thêm query-by-committee hoặc chiến lược diversity-aware, nhưng phải giữ cùng initial set, split và target.

Ưu tiên thứ tư là nâng cấp Fidelity bằng perturbation theo nhóm đặc trưng phù hợp schema PE, kiểm tra miền giá trị và đối chiếu với tệp thực thi khi điều kiện an toàn cho phép. Nếu sử dụng OFS, quy tắc chuẩn hóa, trọng số và phân tích độ nhạy phải được khóa trước trên tập hiệu chỉnh độc lập.

Cuối cùng, hệ thống cần được đo trong một pipeline bất đồng bộ gồm endpoint, sandbox, hàng đợi, dung hợp và dashboard. Chỉ khi có các phép đo này mới có thể chuyển từ bằng chứng thành phần sang kết luận về khả năng triển khai của toàn hệ thống phát hiện ransomware.

Tài liệu tham khảo

[1] Bander Ali Saleh Al-Rimy, Mohd Aizaini Maarof, and Syed Zainudeen Mohd Shaid. Ransomware threat success factors, taxonomy, and countermeasures: A survey and research directions. In *Computers & Security*, volume 74, pages 144–166, 2018.

[2] Hyrum S. Anderson and Phil Roth. EMBER: An open dataset for training static PE malware machine learning models. *arXiv preprint arXiv:1804.04637*, 2018.

[3] Karl J. Åström and Tore Hägglund. The future of PID control. *Control Engineering Practice*, 9(11):1163–1175, 2001.

[4] Alessandro Bacci et al. Ransomware detection using behavioral analysis. *Computers & Security*, 104:102213, 2021. doi: 10.1016/j.cose.2021.102213.

[5] Tianqi Chen and Carlos Guestrin. XGBoost: A scalable tree boosting system. In *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pages 785–794, 2016. doi: 10.1145/2939672.2939785.

[6] David A. Cohn, Zoubin Ghahramani, and Michael I. Jordan. Active learning with statistical models. *Journal of Artificial Intelligence Research*, 4:129–145, 1996.

[7] Tom Fawcett. An introduction to roc analysis. *Pattern Recognition Letters*, 27(8): 861–874, 2006. doi: 10.1016/j.patrec.2005.10.010.

[8] Joao Gama, Indre Zliobaite, Albert Bifet, Mykola Pechenizkiy, and Abdelhamid Bouchachia. A survey on concept drift adaptation. *ACM Computing Surveys*, 46 (4):1–37, 2014. doi: 10.1145/2523813.

[9] Daniel Gibert, Carles Mateu, and Jordi Planes. The rise of machine learning for detection and classification of malware: Research developments, trends and challenges. *Journal of Network and Computer Applications*, 153:102526, 2020.

[10] Riccardo Guidotti, Anna Monreale, Salvatore Ruggieri, Franco Turini, Fosca Giannotti, and Dino Pedreschi. A survey of methods for explaining black box models. *ACM Computing Surveys (CSUR)*, 51(5):1–42, 2018.

[11] Richard Harang and Ethan M. Rudd. SOREL-20M: A large-scale benchmark dataset for malware detection. In *Proceedings of the 14th ACM Workshop on Artificial Intelligence and Security*, pages 1–12, 2020. doi: 10.1145/3411508.3421375.

[12] Guolin Ke, Qi Meng, Thomas Finley, Taifeng Wang, Wei Chen, Weidong Ma, Qiwei Ye, and Tie-Yan Liu. LightGBM: A highly efficient gradient boosting decision tree. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 30, pages 3146–3154, 2017.

[13] Sim Hoong Kok, Azween Abdullah, N. Z. Jhanjhi, and Mahadevan Supramaniam. Ransomware detection survey. *International Journal of Advanced Computer Science and Applications*, 10(8), 2019.

[14] Scott M. Lundberg and Su-In Lee. A unified approach to interpreting model predictions. In *Advances in Neural Information Processing Systems (NeurIPS)*, volume 30, pages 4765–4774, 2017.

[15] Scott M. Lundberg, Gabriel Erion, Hugh Chen, Alex DeGrave, Jordan M. Prutkin, Bala Nair, Ronit Katz, Jonathan Himmelfarb, Nisha Bansal, and Su-In Lee. From local explanations to global understanding with explainable ai for trees. *Nature Machine Intelligence*, 2:56–67, 2020. doi: 10.1038/s42256-019-0138-9.

[16] Microsoft. Pe format: Portable executable and common object file format specification. Microsoft Learn, 2025. URL `https://learn.microsoft.com/en-us/windows/win32/debug/pe-format`. Accessed: 2026-07-08.

[17] Microsoft LightGBM Contributors. Lightgbm documentation: Leaf-wise (best-first) tree growth, 2024. URL `https://lightgbm.readthedocs.io/en/latest/_images/leaf-wise.png`. Accessed: 2026-06-15.

[18] Microsoft Security. The ransomware kill chain, 2020. URL `https://www.microsoft.com/en-us/security/blog/wp-content/uploads/2020/04/Ransomware-Kill-Chain.png`. Accessed: 2026-06-15.

[19] Karl Pearson. Notes on regression and inheritance in the case of two parents. *Proceedings of the Royal Society of London*, 58:240–242, 1895.

[20] Marco Tulio Ribeiro, Sameer Singh, and Carlos Guestrin. "Why should i trust you?": Explaining the predictions of any classifier. In *Proceedings of the 22nd ACM SIGKDD International Conference on Knowledge Discovery and Data Mining*, pages 1135–1144, 2016.

[21] Takaya Saito and Marc Rehmsmeier. The precision-recall plot is more informative than the roc plot when evaluating binary classifiers on imbalanced datasets. *PLOS ONE*, 10(3):e0118432, 2015. doi: 10.1371/journal.pone.0118432.

[22] Burr Settles. Active learning literature survey. Technical Report 1648, University of Wisconsin-Madison Department of Computer Sciences, 2009.

[23] Claude E. Shannon. A mathematical theory of communication. *Bell System Technical Journal*, 27(3):379–423, 1948. doi: 10.1002/j.1538-7305.1948.tb01338.x.

[24] Michael Sikorski and Andrew Honig. *Practical Malware Analysis: The Hands-On Guide to Dissecting Malicious Software*. No Starch Press, San Francisco, CA, USA, 2012.

[25] Daniele Ucci, Leonardo Aniello, and Roberto Baldoni. Survey of machine learning techniques for malware analysis. *Computers & Security*, 81:123–147, 2019. doi: 10.1016/j.cose.2018.11.001.

[26] Wikimedia Commons. Portable executable 32 bit structure, 2011. URL `https://upload.wikimedia.org/wikipedia/commons/1/1b/Portable_Executable_32_bit_Structure_in_SVG_fixed.svg`. Accessed: 2026-06-15.

[27] Chih-Kuan Yeh, Cheng-Yu Hsieh, Arun Sai Suggala, David I Inouye, and Pradeep Ravikumar. On the (in)fidelity and sensitivity of explanations. *Advances in Neural Information Processing Systems*, 32, 2019.

PHỤ LỤC

A.1 Thông tin tái lập các thí nghiệm

Gói xác nhận được lưu tại `results/confirmatory_20261019_ember_identity` của kho mã `https://github.com/doanhjut/thesis2026`. Các run được tạo từ commit `fed4322f58f5bb55ec47833e857370d076592a32` khi working tree sạch. SHA-256 của dataset là:

`69f0ae680846edd95458d1e7aaabe36f8866f4f22a6d11488b126ed026b28963`

SHA-256 của row manifest là:

`a2ca16402653e6cc51fdd7a4857d007faf86807b044d78654f180409c73565bb`

Manifest lưu định danh SHA-256 của mẫu và hash vector đặc trưng; hai hash trên là hash của hai tệp đầu vào. Chạy `sha256sum -c SHA256SUMS` từ gốc thư mục gói để kiểm tra 41 artifacts kết quả.

Bảng A.1: Thông tin được lưu để tái lập

Nhóm	Thông tin đã lưu
Dữ liệu	Hash dataset/manifest, số dòng/cột, nhãn, SHA-256 mẫu, chỉ số nguồn, hash vector và outer-fold manifests.
AL	5 folds, 5 seed, initial set, điểm truy vấn, dự đoán, metric, ngân sách đạt target và 1.375 checkpoint.
Fidelity	25 mô hình, hai baseline, vector SHAP, mask indices, dự đoán trước/sau che, EC, CF và stability.
Kiểm tra	Replay AUC/AP, additivity, số truy vấn, số mask, số dự đoán, hash artifacts và trạng thái từng fold.
Thời gian	Train, query, TreeSHAP và mask prediction theo phạm vi của runner.

A.2 Schema tham chiếu của đặc trưng PE 2.381 chiều

Chỉ số bắt đầu từ 0 và khoảng có dạng $[a, b)$. Feature hashing duy trì số chiều cố định nhưng có thể gây collision; một bucket không luôn ánh xạ duy nhất về một API.

Bảng A.2: Khoảng chỉ số của các nhóm đặc trưng EMBER v2

Nhóm	**Bắt đầu**	**Kết thúc**	**Số chiều**
ByteHistogram	0	256	256
ByteEntropyHistogram	256	512	256
StringExtractor	512	616	104
GeneralFileInfo	616	626	10
HeaderFileInfo	626	688	62
SectionInfo	688	943	255
ImportsInfo	943	2223	1280
ExportsInfo	2223	2351	128
DataDirectories	2351	2381	30
Tổng	0	2381	2381

A.3 Quy ước metric và ngân sách AL

Với các số đếm TP, TN, FP, FN:

$$TPR = \frac{TP}{TP + FN}, \qquad FPR = \frac{FP}{FP + TN}. \tag{A.1}$$

AP được tính theo $AP = \sum_n (R_n - R_{n-1}) P_n$. AULC được tích phân theo ngân sách và chuẩn hóa bởi độ dài khoảng ngân sách, vì vậy cùng miền với metric gốc. Ngân sách AL là $B_r = 200 + 100r$, $r = 0, \ldots, 10$. Target được xác định riêng cho mỗi fold từ AUC full-pool trên validation, không từ test.

Năm seed trong từng fold được lấy trung bình trước khi so phương pháp. Với năm hiệu ứng fold d_f, báo trung bình, độ lệch chuẩn giữa fold, min/max và số fold có $d_f > 0$. Cách tính này tránh dùng 25 cặp fold–seed như 25 tập độc lập.

A.4 Quy ước Fidelity

Bảng A.3: Quy tắc tính các đại lượng đánh giá giải thích

Thành phần	**Quy tắc**
Đối tượng	5 folds $\times$ 5 seed mô hình; 400 mẫu test trong mỗi fold.
SHAP	Đóng góp có dấu trên raw score; bias không thuộc tập chiều được che.
Masking	$k = 10, 25, 50$; baseline mean hoặc median chỉ từ train.
Random control	20 mặt nạ không hoàn lại cho mỗi k, cùng số chiều với top-SHAP.
Faithfulness	Báo AUC drop có random control; FF thô $\lvert p - p_{mask}\rvert/(p + 10^{-12})$ được giữ không cắt ngưỡng.
EC	Pearson giữa tam giác trên của hai ma trận cosine trong không gian đặc trưng chuẩn hóa và SHAP.
CF	Khoảng cách hai tâm nhãn chia cho chuẩn SHAP lớn nhất của một mẫu test.
Stability	Spearman global importance và Jaccard top-k trong cùng fold hoặc khác fold.
OFS	Không tính khi chưa có chuẩn hóa chung và trọng số được kiểm định.

Các cặp EC chia sẻ mẫu nên không được coi là các quan sát độc lập trong kiểm định Pearson. CF dùng nhãn test cho đánh giá hậu kiểm, không tham gia huấn luyện. Mean/-median masking không bảo đảm vector tương ứng tệp PE hợp lệ.

A.5 Điều kiện đánh giá PID

Đánh giá PID cần điểm tĩnh và chuỗi điểm động thật ghép theo cùng SHA-256, cùng chính sách quan sát, thứ tự mẫu và reset trạng thái. Static-only, Dynamic-only, fixed-weight, P, PI và PID phải dùng cùng split, threshold protocol và hai scorer nguồn để cô lập tác động của luật dung hợp. Các metric tối thiểu gồm ROC-AUC, AP, calibration, FPR tại TPR mục tiêu, tỷ lệ qua sandbox, thời gian động và độ trễ đầu cuối. Không sử dụng kết quả AL hoặc Fidelity tĩnh thay cho ablation này.